UNIVERSIDADE ESTADUAL DO TOCANTINS
CURSO DE SISTEMAS DE INFORMAÇÃO

ALÊKSON CASTRO DE SOUZA

CONTROLE DE ACESSO IOT NA GESTÃO IMOBILIÁRIA VIA DSR

Palmas
2026

Dados Internacionais de Catalogação na Publicação (CIP)
Sistema Integrado de Bibliotecas da Universidade Estadual do Tocantins (SIBU)

S729c Souza, Alêkson Castro de.
Controle de acesso IoT na gestão imobiliária via DSR / Alêkson Castro de Souza. – Palmas, TO, 2026.
47 f. : il.
Orientadora: Profa. Me. Tamirys Virgulino.

Trabalho de Conclusão de Curso (Graduação em Sistemas de Informação) – Universidade Estadual do Tocantins, 2026.
1. Internet das Coisas (IoT). 2. Controle de acesso. 3. Gestão imobiliária. 4. Criptografia Ed25519. 5. Design Science Research. I. Virgulino, Tamirys, orient. II. Universidade Estadual do Tocantins. III. Título.

CDU 004.738.5:681.518

UNIVERSIDADE ESTADUAL DO TOCANTINS
CURSO DE SISTEMAS DE INFORMAÇÃO

ALÊKSON CASTRO DE SOUZA

CONTROLE DE ACESSO IOT NA GESTÃO IMOBILIÁRIA VIA DSR

Trabalho de Conclusão de Curso apresentado ao Curso de Sistemas de Informação da Universidade Estadual do Tocantins como requisito parcial para obtenção do título de Bacharel.

Orientadora: Profa. Me. Tamirys Virgulino

Palmas
2026

ALÊKSON CASTRO DE SOUZA

CONTROLE DE ACESSO IOT NA GESTÃO IMOBILIÁRIA VIA DSR

Trabalho de Conclusão de Curso apresentado ao Curso de Sistemas de Informação da Universidade Estadual do Tocantins como requisito parcial para obtenção do título de Bacharel.

Aprovado em: _____ de _____ de 2026.

BANCA EXAMINADORA

Profa. Me. Tamirys Virgulino (Orientadora)
Universidade Estadual do Tocantins – UNITINS

Prof(a). Me./Dr(a). [Membro da Banca 1]
Universidade Estadual do Tocantins – UNITINS

Prof(a). Me./Dr(a). [Membro da Banca 2]
Universidade Estadual do Tocantins – UNITINS

Resumo

O modelo operacional de imobiliárias que gerenciam múltiplos corretores parceiros enfrenta um gargalo crítico no controle de acesso físico a propriedades dispersas. O compartilhamento tradicional de chaves metálicas e senhas de cofres mecânicos carece de rastreabilidade e apresenta riscos severos à segurança patrimonial. Embora fechaduras inteligentes conectadas mitiguem a distribuição de chaves, soluções vigentes pressupõem conectividade contínua à internet, inviabilizando sua aplicação no cenário mais frequente do setor: imóveis desocupados sem plano ativo de banda larga. Este trabalho propõe e avalia, sob a metodologia Design Science Research (DSR), um artefato de controle de acesso inteligente baseado em Internet das Coisas (IoT), validado em ambiente simulado, capaz de gerenciar com segurança o acesso temporário de múltiplos parceiros a imóveis desprovidos de conexão de rede. A solução integra controle de acesso baseado em atributos (ABAC contextual) a tokens criptográficos assinados digitalmente com o algoritmo de curva elíptica Ed25519, transmitidos via QR Code e verificados localmente pelo microcontrolador da fechadura em milissegundos, com sincronização assíncrona de auditoria via protocolo MQTT. A avaliação do artefato é estruturada por meio de simulação virtual em nós microcontrolados e testes automatizados de integração, estabelecendo métricas de latência temporal, ocupação de memória e eficácia de contenção lógica, com o intuito de fundamentar uma alternativa arquitetural de baixo custo e auditável no setor imobiliário.

Palavras-chave: Internet das Coisas (IoT). Controle de Acesso. Gestão Imobiliária. Criptografia Ed25519. Design Science Research.

Abstract

The operational model of real estate agencies managing multiple partner brokers faces a critical bottleneck in physical access control to dispersed properties. Traditional sharing of physical keys and lockbox passcodes lacks traceability and poses severe security risks. Although connected smart locks mitigate key handover logistics, current IoT solutions rely on continuous internet connectivity, failing in the sector's most common scenario: vacant properties without active broadband connections. This work proposes and evaluates, following the Design Science Research (DSR) methodology, an Internet of Things (IoT) intelligent access control artifact, validated in a simulated environment, capable of securely managing temporary access for multiple partners to offline properties. The solution couples Attribute-Based Access Control (contextual ABAC) with cryptographic tokens digitally signed via the Ed25519 elliptic curve algorithm, delivered through QR Codes and verified locally by the microcontrolled lock within milliseconds, alongside asynchronous audit synchronization via the MQTT protocol. The artifact evaluation is structured through virtual microcontroller simulation and automated integration tests, establishing performance metrics for latency, memory footprint, and logical containment efficacy, aiming to support an auditable and cost-effective architectural alternative tailored for real estate operations.

Keywords: Internet of Things (IoT). Access Control. Real Estate Management. Ed25519 Cryptography. Design Science Research.

Lista de abreviaturas e siglas

ABAC	*Attribute-Based Access Control* (Controle de Acesso Baseado em Atributos)
AES	*Advanced Encryption Standard* (Padrão de Criptografia Avançada)
API	*Application Programming Interface* (Interface de Programação de Aplicação)
ARM	*Advanced RISC Machine* (Arquitetura de Processadores Embarcados)
BC-SNOA	*Blockchain-based Secure and Non-interactive Offline Authentication*
BLE	*Bluetooth Low Energy* (Bluetooth de Baixa Energia)
DSR	*Design Science Research* (Metodologia de Pesquisa do Artefato)
ECC	*Elliptic Curve Cryptography* (Criptografia de Curva Elíptica)
ECDSA	*Elliptic Curve Digital Signature Algorithm*
Ed25519	*Edwards-curve Digital Signature Algorithm 25519*
ESP32	Microcontrolador de Baixo Custo com Wi-Fi e Bluetooth Integrados
HABAC	*Hierarchical Attribute-Based Access Control*
HMAC	*Hash-based Message Authentication Code*
HTTP	*Hypertext Transfer Protocol*
IoT	*Internet of Things* (Internet das Coisas)
JSON	*JavaScript Object Notation* (Formato de Carga Útil do Token)
MQTT	*Message Queuing Telemetry Transport* (Protocolo de Mensageria Leve)
OTMP-P2L	*One-Time Multi-Party Proof to Lock*
OTP	*One-Time Password* (Senha de Uso Único)
PoW	*Proof of Work* (Prova de Trabalho Criptográfica)
QR Code	*Quick Response Code* (Código Bidimensional de Transporte do Token)
RBAC	*Role-Based Access Control* (Controle de Acesso Baseado em Papéis)
SHA	*Secure Hash Algorithm* (Função Hash Criptográfica)
TLS	*Transport Layer Security* (Segurança da Camada de Transporte)
TTL	*Time-To-Live* (Tempo de Vida Útil do Token)
Wi-Fi	*Wireless Fidelity* (Rede Local sem Fio)
zk-SNARK	*Zero-Knowledge Succinct Non-Interactive Argument of Knowledge*

Sumário

1 INTRODUÇÃO 10
1.1 Contextualização 10
1.2 Problema de Pesquisa 11
1.3 Objetivo Geral 11
1.4 Objetivos Específicos 12
1.5 Justificativa 12
1.6 Estrutura do Trabalho 12

2 FUNDAMENTAÇÃO TEÓRICA 14
2.1 Internet das Coisas (IoT): Conceitos e Arquitetura 14
2.1.1 Definição e Desafios em Dispositivos Conectados 14
2.1.2 Arquitetura em Camadas e Gateways de Borda 14
2.1.3 Protocolo de Mensageria Leve: MQTT 15
2.2 Controle de Acesso em Ambientes IoT 16
2.2.1 Controle de Acesso Baseado em Papéis (RBAC) e Suas Limitações 16
2.2.2 Controle de Acesso Baseado em Atributos (ABAC) e o Modelo HABACα . 16
2.2.3 Autenticação Temporária por Tokens Efêmeros 17
2.2.4 Criptografia Assimétrica e Verificação Offline em Dispositivos de Borda . . 17
2.3 Fechaduras Inteligentes e Trabalhos Relacionados 18
2.3.1 Limitações dos Mecanismos Tradicionais de Acesso Físico 18
2.3.2 Sistemas de Fechaduras Baseados em IoT 18
2.3.3 Análise Comparativa do Estado da Arte 20
2.4 Segurança, Rastreabilidade e Auditoria em Sistemas IoT 21
2.4.1 Vetores de Ataque e Vulnerabilidades Comuns 21
2.4.2 Mecanismos de Proteção e Trilhas de Auditoria 21

3 METODOLOGIA DE PESQUISA 23
3.1 Caracterização Metodológica 23
3.1.1 Design Science Research como Paradigma 23
3.2 Contexto e Formalização do Problema 24
3.2.1 Cenário de Gestão de Visitas e Análise dos Métodos Vigentes 24
3.2.2 Questão de Pesquisa e Pilares do Artefato 24
3.3 Procedimentos e Instrumentos de Avaliação 25
3.3.1 Ambiente de Simulação Virtual 25
3.3.2 Planejamento dos Cenários de Demonstração 25
3.3.3 Métricas Quantitativas e Tratamento Estatístico 25

4 DESENVOLVIMENTO DO ARTEFATO E RESULTADOS 27
4.1 Arquitetura Geral do Artefato Desenvolvido 27
4.1.1 Visão em Camadas do Ecossistema IoT 27
4.1.2 Componentes Arquiteturais e Domínios do Sistema 27
4.2 Modelo de Autorização Baseado em Atributos (ABAC) 29
4.2.1 Transição do RBAC ao ABAC no Contexto Imobiliário 29
4.2.2 Dicionário de Atributos do Sistema 29
4.2.3 Arquitetura Funcional segundo o Padrão NIST SP 800-162 29
4.2.4 Formalização das Regras de Acesso e Algoritmo de Combinação 31
4.3 Modelo Criptográfico e Validação Offline 32
4.3.1 O Paradigma da Validação Desconectada (Analogia EMV) 32
4.3.2 Seleção do Algoritmo Criptográfico Ed25519 32
4.3.3 Estrutura do Token de Acesso 33
4.3.4 Algoritmo de Verificação Local no ESP32 33
4.3.5 Prevenção contra Ataques e Gestão do Buffer Anti-Replay 35
4.4 Fluxo de Operação de Ponta a Ponta 35
4.4.1 Fase 1: Solicitação e Emissão do Token (Online) 35
4.4.2 Fase 2: Apresentação e Validação Local (Offline) 37
4.4.3 Fase 3: Sincronização Assíncrona e Auditoria 37
4.5 Stack Tecnológica e Especificação do Firmware 38
4.5.1 Mapeamento dos Componentes Tecnológicos 38
4.5.2 Organização Modular do Firmware no ESP32 38
4.5.3 Endpoints e Motor de Inferência em FastAPI 39
4.5.4 Estrutura de Mensageria e Tópicos MQTT 39
4.6 Bancada de Simulação Virtual no Wokwi 40
4.6.1 Mapeamento do Circuito Eletrônico e Pinout 40
4.7 Resultados da Demonstração nos Cenários Operacionais 41
4.7.1 Cenário 1: Concessão de Acesso Válido em Fluxo Nominal 41
4.7.2 Cenário 2: Robustez contra Acessos Inválidos e Vetores de Ataque 41
4.7.3 Cenário 3: Revogação Cadastral e Resposta do Nó Desconectado 42
4.8 Avaliação Quantitativa e Análise Experimental 42
4.8.1 Desempenho Temporal e Latência de Ponta a Ponta 43
4.8.2 Consumo de Recursos Computacionais no ESP32 43
4.8.3 Vazão de Auditoria e Eficácia de Segurança 43
4.8.4 Quadro Consolidado de Resultados Experimentais 44
4.8.5 Discussão dos Resultados e Confronto com o Estado da Arte 45

5 CONCLUSÃO 46
5.1 Trabalhos futuros 46

REFERÊNCIAS 47

1 Introdução

1.1 Contextualização

O mercado imobiliário apoia-se em redes colaborativas de intermediação, nas quais administradoras gerenciam carteiras extensas de propriedades distribuídas geograficamente. Para viabilizar a comercialização e a locação desse patrimônio, as empresas dependem da atuação de dezenas de corretores autônomos e parceiros externos. Essa atividade impõe uma dinâmica operacional ágil e imprevista: visitas a imóveis costumam ser solicitadas por clientes em janelas de tempo reduzidas, com frequência fora do horário comercial, como no início da noite, intervalos de almoço ou finais de semana. Paralelamente às visitas comerciais, o ecossistema demanda acesso frequente para vistorias técnicas, serviços de limpeza, reparos de manutenção e registros fotográficos para divulgação em plataformas digitais.

Apesar da modernização dos sistemas de gestão e dos portais de anúncio, o controle de acesso físico às propriedades permanece dependente de métodos convencionais, centralizado no uso de chaves metálicas. Na prática, quando um corretor parceiro agenda um atendimento, precisa deslocar-se previamente até a sede da imobiliária para retirar o molho de chaves da unidade, assinar fichas de protocolo em papel, dirigir-se ao imóvel para a demonstração e, em seguida, retornar à sede para restituir o chaveiro. Esse procedimento gera atrito logístico constante: consome tempo excessivo em deslocamentos no trânsito, eleva despesas com combustível e frequentemente inviabiliza visitas quando a imobiliária encontra-se fechada, gerando perda de oportunidades comerciais.

Para contornar essa lentidão operacional, o mercado recorre a soluções de contingência frágeis, como deixar cópias com porteiros de condomínios sob guarda de terceiros ou instalar cofres mecânicos com segredo numérico (*lockboxes*) presos a portões externos. Chaves físicas podem ser duplicadas em chaveiros comuns em poucos minutos sem qualquer registro formal (SILVA; SAMANIEGO; DETERS, 2023). Já os cofres mecânicos utilizam senhas estáticas de quatro dígitos compartilhadas informalmente por aplicativos de mensagens instantâneas entre dezenas de profissionais, combinações que raramente são alteradas e mantêm o acesso aberto a corretores desvinculados por meses (SATANASAOWAPAK; MANASATHIEN; TREEBUPACHATSAKUL, 2021). O principal agravante desse cenário reside na total ausência de auditoria: caso ocorram avarias, torneiras abertas ou furtos de fiação, a administração não dispõe de meios para apurar quem acessou a unidade, em qual data e quanto tempo permaneceu no local.

A alternativa intuitiva seria a adoção de fechaduras inteligentes conectadas ao ecossistema de Internet das Coisas (*Internet of Things* – IoT). Entretanto, as opções comerciais vigentes foram projetadas para residências habitadas, operando sob a premissa de conexão ininterrupta a

redes locais sem fio (Wi-Fi) vinculadas à nuvem (VARDAKIS et al., 2024). Esse modelo colide com a realidade do setor: imóveis desocupados ofertados para venda ou locação encontram-se desprovidos de planos de banda larga fixa, visto que proprietários e administradores evitam assumir custos mensais de conexão durante o período de vacância. Sem infraestrutura de rede local no imóvel, os dispositivos convencionais tornam-se inoperantes ou recuam para o uso das mesmas chaves físicas, neutralizando os benefícios da automação.

Diante do dilema entre a necessidade de delegação ágil e a inexistência de conectividade no local, este trabalho desenvolve uma resposta arquitetural ao problema. A abordagem transfere a camada de conectividade para o único elemento provido de internet no instante da visita: o smartphone do corretor, que dispõe de conexão móvel celular (4G/5G). A fechadura embarcada opera de forma estritamente offline, utilizando criptografia de curvas elípticas (Ed25519) e avaliação dinâmica de políticas por atributos (ABAC contextual). O corretor requisita a permissão à nuvem, recebe o token assinado e o apresenta localmente via leitura óptica de QR Code; o microcontrolador valida a credencial matematicamente e aciona o destravamento, permitindo a sincronização assíncrona dos registros de auditoria via protocolo MQTT. A pesquisa é conduzida sob a metodologia *Design Science Research* (DSR), orientando a concepção teórica, a implementação em bancada simulada e a avaliação experimental do artefato.

1.2 Problema de Pesquisa

O problema que orienta esta pesquisa desdobra-se em duas dimensões complementares: a operacional, decorrente da ausência de mecanismos centralizados e auditáveis para gerenciar o acesso temporário de parceiros; e a técnica, decorrente da exigência de conexão de rede nas soluções IoT convencionais, inoperantes em imóveis desocupados.

Diante desse cenário, define-se a seguinte pergunta de pesquisa:

> *Como projetar e avaliar uma arquitetura de controle de acesso inteligente baseada em IoT capaz de gerenciar, de forma segura, rastreável e orientada a atributos (ABAC), o acesso temporário de múltiplos corretores parceiros a imóveis desocupados desprovidos de conexão à internet?*

1.3 Objetivo Geral

Projetar e avaliar, por meio da metodologia *Design Science Research* (DSR), um artefato IoT de controle de acesso que permita a imobiliárias gerenciar com segurança e rastreabilidade o acesso de corretores parceiros a imóveis offline, utilizando tokens assinados com o algoritmo Ed25519, validados em ambiente simulado.

1.4 Objetivos Específicos

1. **Mapear o estado da arte** em autenticação offline, mensageria leve com MQTT (*Message Queuing Telemetry Transport*) e criptografia de curva elíptica (ECC – *Elliptic Curve Cryptography*), de modo a fundamentar as decisões arquiteturais da proposta.

2. **Modelar a arquitetura** do sistema em camadas, integrando controle de acesso baseado em atributos (ABAC contextual – *Attribute-Based Access Control*) a tokens Ed25519 verificáveis offline.

3. **Implementar o protótipo simulado** cobrindo os cenários de acesso concedido, negado por inconsistência de atributos e revogação de permissões, diferenciando o bloqueio imediato na emissão em nuvem da contenção temporal por expiração (TTL) no nó offline.

4. **Avaliar o protótipo** quanto à latência de verificação offline da assinatura Ed25519 no microcontrolador e à latência de comunicação MQTT na fase de emissão do token, além da eficácia na contenção de acessos indevidos.

1.5 Justificativa

Os problemas mapeados na contextualização não são independentes: a falha operacional, o risco de segurança e a limitação tecnológica se reforçam mutuamente, e nenhuma solução disponível os endereça de forma integrada. É nessa interseção que o presente trabalho se posiciona, com justificativa distribuída em três planos:

Plano prático. A substituição de chaves físicas e senhas estáticas de *lockboxes* elimina riscos de cópia não autorizada (SATANASAOWAPAK; MANASATHIEN; TREEBUPACHATSAKUL, 2021) e reduz a dependência de plataformas proprietárias sujeitas a vazamento de credenciais (SILVA; SAMANIEGO; DETERS, 2023), assegurando à imobiliária controle e auditoria confiáveis.

Plano técnico. Demonstra-se viável executar verificação criptográfica assimétrica por curvas elípticas (ECC) de maneira estritamente offline em microcontroladores de baixo custo, com tempo de resposta na ordem de milissegundos (HAN et al., 2018; HAN; DU; LU, 2020).

Plano acadêmico. O estudo preenche a lacuna de integrar autenticação offline, políticas baseadas em atributos (ABAC contextual) e sincronização assíncrona de auditoria sob uma arquitetura voltada ao setor imobiliário.

1.6 Estrutura do Trabalho

O trabalho organiza-se em cinco capítulos: o Capítulo 2 apresenta a fundamentação teórica e os trabalhos correlatos; o Capítulo 3 descreve o método DSR adotado; o Capítulo 4 apresenta

a concepção arquitetural do artefato e a projeção dos resultados esperados; e o Capítulo 5 sintetiza as contribuições e propõe trabalhos futuros.

2 Fundamentação Teórica

Este capítulo apresenta a base teórica e tecnológica que sustenta a concepção e a modelagem do artefato proposto neste trabalho. A discussão está estruturada em quatro eixos temáticos: (i) Internet das Coisas (IoT), sua arquitetura em camadas e protocolos de mensageria leve; (ii) modelos de controle de acesso e autorização dinâmica em ambientes computacionais restritos, incluindo a criptografia assimétrica para validação offline em dispositivos de borda; (iii) fechaduras inteligentes, acompanhadas de análise comparativa do estado da arte, com ênfase em esquemas de autenticação sem conectividade de rede; e (iv) segurança, rastreabilidade e trilhas de auditoria em ecossistemas IoT.

2.1 Internet das Coisas (IoT): Conceitos e Arquitetura

2.1.1 Definição e Desafios em Dispositivos Conectados

A Internet das Coisas (*Internet of Things* – IoT) consiste na interconexão digital de objetos físicos à infraestrutura de rede, permitindo que sensores, atuadores e microcontroladores realizem a coleta, o processamento e a troca autônoma de dados sem intervenção humana contínua (VARDAKIS et al., 2024).

Entretanto, Vardakis et al. (2024) e Researchers (2022) ressaltam que o avanço da IoT expõe desafios críticos de segurança decorrentes da heterogeneidade e da severa restrição computacional dos nós de borda. Ao contrário de servidores de aplicação ou estações de trabalho, dispositivos embarcados em extremidades de rede operam com processadores de baixo custo, memória volátil reduzida e capacidade energética limitada. Tal restrição inviabiliza a execução local de pilhas criptográficas complexas ou algoritmos pesados de avaliação de políticas de segurança (RESEARCHERS, 2021).

Diante desse cenário, torna-se imperativo projetar arquiteturas computacionais que dissociem a tarefa de decisão de acesso da tarefa de atuação física. Essa diretriz fundamenta diretamente o desenvolvimento do presente trabalho, no qual o dispositivo de acionamento da trava no imóvel atua exclusivamente na execução de ordens validadas previamente por uma infraestrutura centralizada.

2.1.2 Arquitetura em Camadas e Gateways de Borda

A literatura científica adota predominantemente a representação de sistemas IoT organizada em quatro camadas hierárquicas, estruturando o fluxo de dados desde a captura física até a interação com o usuário final (VARDAKIS et al., 2024):

1. **Camada Física e de Percepção:** Abrange o hardware embarcado, atuadores mecânicos (fechaduras elétricas ou solenóides), sensores de presença e leitores de entrada de credenciais (interfaces de leitura de QR Code, biometria ou teclados).

2. **Camada de Rede:** Fornece a infraestrutura de transmissão de dados via enlaces locais (Wi-Fi, Bluetooth) ou remotos, conectando dispositivos locais aos servidores de controle por meio de protocolos de transporte e aplicação dedicados.

3. **Camada de Middleware e Processamento:** Responsável pelo processamento lógico, aplicação de políticas de autorização, gerenciamento de regras temporais e persistência de dados.

4. **Camada de Aplicação:** Engloba os painéis administrativos web e aplicativos móveis voltados aos administradores imobiliários e aos corretores autorizados.

Para mitigar a vulnerabilidade decorrente da exposição direta de microcontroladores à internet pública, Vardakis et al. (2024) e Ameer et al. (2022) preconizam a inserção de um *gateway* local ou de borda (*edge gateway*). O gateway centraliza a comunicação local, atua como intermediário na validação criptográfica e isola os dispositivos físicos de varreduras externas de rede.

2.1.3 Protocolo de Mensageria Leve: MQTT

O MQTT (*Message Queuing Telemetry Transport*) é um protocolo de mensageria assíncrona baseado no padrão de publicação e subscrição (*publish/subscribe*), concebido especificamente para redes com largura de banda limitada e dispositivos com recursos restritos (AMEER et al., 2022). No modelo MQTT, clientes publicam mensagens associadas a tópicos específicos em um intermediário central (*broker*), o qual roteia os dados unicamente para os clientes previamente inscritos nesses mesmos canais de interesse.

Em sistemas de segurança física, o MQTT viabiliza o envio imediato e bidirecional de comandos e telemetrias com sobrecarga (*overhead*) de cabeçalho substancialmente inferior àquela gerada pelo protocolo HTTP tradicional (AUTHORS, 2024). Ameer et al. (2022) demonstraram que a aplicação de MQTT combinada à criptografia de transporte via TLS (*Transport Layer Security*) oferece canais resilientes e com tempos de propagação de mensagens da ordem de milissegundos, impedindo a interceptação passiva e a adulteração de comandos de acionamento. Ademais, Researchers (2024) validam experimentalmente que o MQTT associado a microcontroladores como o ESP32 mantém estabilidade de latência em cenários simulados de controle de tráfego.

Essa eficiência operacional orienta a escolha do MQTT no artefato deste estudo, viabilizando o despacho em tempo real do evento de abertura para a fechadura imediatamente após a validação da permissão do corretor pelo servidor.

2.2 Controle de Acesso em Ambientes IoT

2.2.1 Controle de Acesso Baseado em Papéis (RBAC) e Suas Limitações

O modelo de Controle de Acesso Baseado em Papéis (*Role-Based Access Control* – RBAC) fundamenta-se na concessão de privilégios a determinados papéis organizacionais (*roles*), atribuindo posteriormente os usuários a essas categorias pré-definidas (AMEER et al., 2022). Trata-se do padrão amplamente implementado em sistemas de informação corporativos tradicionais devido à simplicidade administrativa inicial que oferece.

Contudo, investigações recentes apontam que o RBAC apresenta rigidez excessiva quando transposto para ambientes ubíquos e IoT dinâmicos (AMEER et al., 2022; RESEARCHERS, 2021). Em um ecossistema imobiliário, por exemplo, a atribuição estática do papel "Corretor" revela-se insuficiente para a segurança da operação: conceder acesso ilimitado com base apenas na função profissional impediria restringir o acesso a um imóvel específico, a uma faixa de horário comercial determinada ou a uma data de agendamento confirmada. Para reproduzir tais restrições no RBAC, o administrador seria obrigado a multiplicar papéis de forma insustentável (*role explosion*) (AMEER et al., 2022).

Portanto, evidencia-se a necessidade de adotar modelos mais expressivos, capazes de fundamentar decisões de autorização em dados contextuais em vez de relações binárias entre usuários e funções organizacionais.

2.2.2 Controle de Acesso Baseado em Atributos (ABAC) e o Modelo HABACα

O Controle de Acesso Baseado em Atributos (*Attribute-Based Access Control* – ABAC) supera as limitações do RBAC ao computar permissões a partir da avaliação dinâmica de atributos pertencentes a quatro categorias: sujeito (identidade do usuário, certificação do corretor), recurso (identificador do imóvel, estado da fechadura), ação pretendida (destravar, auditar) e ambiente (data, hora, geolocalização ou duração da visita) (AMEER et al., 2022; AUTHORS, 2022).

A flexibilidade do ABAC foi aprimorada por Ameer et al. (2022) na formulação do modelo HABACα (*Home Attribute-Based Access Control*), voltado ao ecossistema de residências inteligentes. O HABACα formaliza políticas de autorização sensíveis ao contexto que consideram a hierarquia espacial do imóvel e condicionantes temporais estritas. Sob o HABACα, a autorização deixa de ser uma permissão perpétua e torna-se um evento transitório, revogado no instante em que qualquer condição contextual (como o término do horário estipulado) for violada (AMEER et al., 2022).

Essa formulação conceitual é diretamente transposta para a arquitetura desta pesquisa: o corretor parceiro apenas obtém acesso ao imóvel se preencher concomitantemente o vínculo ativo com a imobiliária, o agendamento prévio cadastrado e a janela cronológica precisa da visita.

2.2.3 Autenticação Temporária por Tokens Efêmeros

Para que as políticas avaliadas pelo motor ABAC sejam executadas com agilidade na ponta sem sobrecarregar a fechadura, adota-se o paradigma de autenticação temporária desacoplada mediante tokens efêmeros (SATANASAOWAPAK; MANASATHIEN; TREEBUPACHATSAKUL, 2021). Sob essa abordagem, a infraestrutura central de autorização gera um código criptográfico temporizado dotado de tempo de vida útil reduzido (*Time-To-Live* – TTL), entregue digitalmente ao dispositivo do solicitante.

Satanasaowapak, Manasathien e Treebupachatsakul (2021) propuseram um sistema de fechadura inteligente baseado em tokens descartáveis e senhas temporárias (OTP), demonstrando que o uso de credenciais que expiram automaticamente anula o risco associado ao roubo, compartilhamento ou vazamento posterior de senhas estáticas. De modo complementar, Researchers (2022) ressaltam que tokens efêmeros permitem delegar ao cliente a comprovação de sua legitimidade com baixíssima complexidade de checagem no dispositivo de atuação.

Assim, a geração de tokens dinâmicos no artefato deste TCC garante que a chave digital permaneça válida estritamente pelo intervalo necessário para a vistoria do imóvel, impedindo reutilizações indevidas por corretores ou terceiros após o término do evento.

2.2.4 Criptografia Assimétrica e Verificação Offline em Dispositivos de Borda

A adoção de criptografia assimétrica baseada em curvas elípticas (ECC — *Elliptic Curve Cryptography*) representa uma solução computacionalmente viável para implementar autenticação robusta em microcontroladores restritos sem depender de conectividade de rede no momento do acesso (HAN et al., 2018). Ao contrário de protocolos simétricos que exigem o compartilhamento prévio de um segredo entre remetente e receptor, o modelo assimétrico separa claramente as responsabilidades: a chave privada, custodiada com exclusividade pelo servidor central, assina digitalmente o token de acesso durante a fase de agendamento online; a chave pública correspondente, gravada em memória não volátil do microcontrolador, executa apenas a verificação criptográfica dessa assinatura no momento do destravamento (HAN; DU; LU, 2020).

Essa dissociação atende diretamente ao cenário de imóveis desocupados sem infraestrutura de rede local: o dispositivo de borda não precisa consultar qualquer servidor para validar a autenticidade e a vigência da credencial. O processo de verificação de uma assinatura ECC é uma operação matemática de custo computacional reduzido e tempo constante, executável em centenas de milissegundos mesmo em processadores de baixo consumo energético. Han, Du e Lu (2020) validaram experimentalmente essa premissa ao construir um protótipo de fechadura inteligente offline com validação completa em apenas 339 milissegundos em um microcontrolador ARM Cortex-A7, demonstrando que a arquitetura de verificação local alia rigor de segurança à agilidade operacional para o usuário final.

A curva Ed25519, variante de assinatura de alta performance derivada da Curve25519,

destaca-se nesse contexto por oferecer chaves de apenas 32 bytes, assinaturas de 64 bytes e resistência comprovada a ataques de canal lateral, sendo implementada nativamente nas principais bibliotecas de criptografia embarcada (HAN et al., 2018). Esse conjunto de propriedades fundamenta a escolha do esquema de assinatura digital assimétrica como mecanismo central de autenticação offline no artefato proposto neste trabalho.

2.3 Fechaduras Inteligentes e Trabalhos Relacionados

2.3.1 Limitações dos Mecanismos Tradicionais de Acesso Físico

Os mecanismos tradicionais de controle de acesso a imóveis dependem prioritariamente de chaves metálicas mecânicas ou de cartões magnéticos e códigos numéricos estáticos (SATANASAOWAPAK; MANASATHIEN; TREEBUPACHATSAKUL, 2021; SILVA; SAMANIEGO; DETERS, 2023). No contexto operacional de imobiliárias que gerenciam dezenas ou centenas de propriedades distribuídas geograficamente, esse paradigma acarreta severas deficiências práticas.

Primeiramente, o manuseio de chaves físicas impõe sobrecarga logística, exigindo que corretores parceiros desloquem-se até a sede da empresa apenas para retirar e devolver os chaveiros, além de expor os proprietários ao risco de clonagem clandestina de lâminas metálicas sem qualquer vestígio (SATANASAOWAPAK; MANASATHIEN; TREEBUPACHATSAKUL, 2021). Em segundo lugar, senhas estáticas compartilhadas por mensagens informais tendem a ser repassadas entre corretores e prestadores de serviços, tornando impossível assegurar quem de fato acessou o recinto (SILVA; SAMANIEGO; DETERS, 2023). Finalmente, tais métodos não produzem registros automatizados de entrada e saída, impedindo auditorias eficientes caso ocorram furtos ou danos aos imóveis.

O Quadro 1 sintetiza as principais características e fragilidades desses métodos frente aos requisitos demandados pelo cenário investigado e pelo artefato proposto.

2.3.2 Sistemas de Fechaduras Baseados em IoT

A substituição de cilindros mecânicos por fechaduras inteligentes conectadas (*smart locks*) transforma o ponto de acesso em um nó computacional autônomo. O acionamento da tranca passa a ser intermediado por sinais eletrônicos condicionados à verificação de credenciais digitais móveis, biometria facial ou leitura de códigos bidimensionais (QR Codes) (SATANASAOWAPAK; MANASATHIEN; TREEBUPACHATSAKUL, 2021; AUTHORS, 2025).

Diversos projetos acadêmicos e comerciais vêm aplicando essa transição. Authors (2025) utilizam visão computacional embarcada para identificação facial em fechaduras inteligentes residenciais. Contudo, conforme apontado por Authors (2024), abordagens dependentes exclusivamente de hardware biométrico local aumentam exponencialmente o custo unitário por porta, além de criarem barreiras de privacidade e exigirem o cadastramento facial prévio de

Tabela 1 – Comparação entre métodos convencionais de controle de acesso e o artefato proposto.

Método	**Rastreabilidade**	**Revogação**	**Modo Offline**	**Limitação Principal**
Chave física metálica	Não	Não	Sim	Risco de cópia ou extravio não registrado (SILVA; SAMANIEGO; DETERS, 2023).
Cofre mecânico com segredo (*lockbox*)	Não	Não	Sim	Senhas estáticas repassadas informalmente entre dezenas de corretores.
Teclado numérico local (*PIN pad*)	Não	Parcial	Sim	Vulnerável à observação de terceiros (*shoulder surfing*) e ataques de força bruta (AUTHORS, 2024).
Fechadura inteligente comercial (Wi-Fi)	Sim	Sim	Não	Depende de conexão fixa local com servidores do fabricante (VARDAKIS et al., 2024).
Artefato proposto (DSR)	**Sim**	**Sim**	**Sim**	**Validação por chave pública e delegação por token com TTL.**

Fonte: Elaborado pelo autor (2026).

todos os corretores parceiros em cada dispositivo instalado. Por sua vez, fechaduras comerciais dependentes de nuvens proprietárias expõem o administrador ao confinamento tecnológico (*vendor lock-in*) e a custos contínuos de assinatura (SILVA; SAMANIEGO; DETERS, 2023).

Nesse cenário, dois trabalhos acadêmicos se destacam pela abordagem pioneira de autenticação offline em fechaduras inteligentes. Han et al. (2018) propuseram o BC-SNOA (*Blockchain-based Succinct Non-interactive Offline Authentication*), um esquema que combina criptografia de curva elíptica (ECC — Secp256k1), Prova de Trabalho (PoW) baseada em SHA-256 e provas de conhecimento zero (zk-SNARKs) para permitir que a fechadura valide o QR Code apresentado pelo usuário de forma completamente offline, sem consultar qualquer servidor ou nuvem no momento do destravamento. O token é gerado durante a fase de reserva online e encapsulado em um código QR entregue ao smartphone do usuário; na porta, a fechadura executa a verificação matemática local e aciona o mecanismo de abertura sem qualquer dependência de conectividade.

Han, Du e Lu (2020) avançaram sobre essa proposta com o esquema OTMP-P2L (*One-Time Association Multitask Proofs for Peer to Local Authentication*), estruturado em torno de provas de conhecimento zero encadeadas baseadas em problemas NP: prova de período temporal (ECC homomórfico), prova de token legítimo (HMAC e assinatura ECC), prova de trabalho (PoW SHA-256) e verificação de pertencimento ao grupo por meio do acumulador unidirecional de Nyberg. Em testes físicos com microcontrolador ARM Cortex-A7 e leitor de QR Code, os autores alcançaram tempo de validação completa de apenas 339 milissegundos e tamanho de token de 593 bytes — resultados que demonstram a plena viabilidade da abordagem em hardware restrito de baixo custo.

2.3.3 Análise Comparativa do Estado da Arte

Para fundamentar as escolhas arquiteturais e demonstrar a lacuna tecnológica atendida por esta pesquisa, o Quadro 2 sintetiza a comparação crítica entre as principais soluções identificadas na literatura recente frente à proposta deste trabalho.

Tabela 2 – Comparação entre soluções da literatura e a arquitetura proposta.

Trabalho / Autor	**Mecanismo**	**Protocolo**	**Controle / Aut.**	**Lacuna Identificada**
Satanasaowapak, Manasathien e Treebupachatsakul (2021)	OTP / Token Web	HTTP / Web Server	Estático temporizado	Dependência de servidor web local; sem suporte ABAC contextual.
Ameer et al. (2022) (HABACα)	Atributos / App	MQTT / TLS	ABAC formal hierárquico	Focado em residências unifamiliares; não aborda terceirização ou múltiplos parceiros.
Vardakis et al. (2024)	Gateway Smart Home	Não especificado	Baseado em papéis	Abordagem genérica de segurança; ausência de protótipo de acesso físico.
Silva, Samaniego e Deters (2023)	Smart Contracts / IoT	Blockchain	Descentralizado / P2P	Alta sobrecarga computacional e latência de mineração; inviável em cenários de baixo custo.
Authors (2024)	Biometria / Senha	Wi-Fi / Cloud	Autenticação local	Custo elevado por nó; vulnerável ao compartilhamento presencial de senhas.
Authors (2025)	Visão (YOLOv5)	Rede local	Reconhecimento Facial	Alto consumo de processamento; exige pré-cadastro de faces para cada corretor.
Han et al. (2018) (BCSNOA)	ECC + PoW + zk-SNARK + QR Code	Nenhum (offline)	Criptográfico offline	Contexto de reserva de salas corporativas; sem ABAC imobiliário; sem ESP32.
Han, Du e Lu (2020) (OTMP-P2L)	ECC + PoW + HMAC + Acumulador Nyberg	Nenhum (offline)	Provas NP encadeadas	Prova de conceito em ARM; sem rastreabilidade de auditoria; sem contexto imobiliário.
Artefato Proposto	**Token Ed25519 / ABAC**	**QR Code Offline**	**ABAC Contextual Offline**	**Baixo custo, validação 100% offline sem Wi-Fi no imóvel, múltiplos parceiros e trilha completa de auditoria.**

Fonte: Elaborado pelo autor (2026).

A comparação evidenciada no Quadro 2 ratifica que, conquanto existam iniciativas sofisticadas baseadas em blockchain (SILVA; SAMANIEGO; DETERS, 2023) ou visão computacional (AUTHORS, 2025), persiste uma carência de arquiteturas enxutas que combinem baixo custo de implantação, autorização contextual dinâmica (ABAC) e auditoria transparente para ambientes

corporativos com múltiplos atores externos.

2.4 Segurança, Rastreabilidade e Auditoria em Sistemas IoT

2.4.1 Vetores de Ataque e Vulnerabilidades Comuns

No modelo proposto, três vetores de ataque são especialmente críticos: a interceptação do token em trânsito, a reutilização de um QR Code já utilizado e o uso indevido do smartphone do corretor como ponto de decisão de segurança (AUTHORS, 2024; RESEARCHERS, 2021). A espionagem passiva (*eavesdropping*), os ataques de repetição (*replay attacks*) e a interceptação ativa (*man-in-the-middle*) são os mecanismos concretos associados a esses vetores (AUTHORS, 2024). A ausência de criptografia de transporte no MQTT permitiria que um invasor capturasse o comando de abertura e o replicasse para destrancar o imóvel em momento posterior.

Em cenários de validação offline, o risco de reutilização de tokens persiste mesmo sem acesso à rede: um atacante que capture o QR Code durante uma visita pode tentar apresentá-lo novamente após o encerramento da janela temporal autorizada. Para neutralizar essa ameaça, o artefato proposto associa a cada token um identificador único de uso único (*nonce* — campo `jti` do JWT), cujo registro é persistido em buffer circular na memória não volátil (NVS Flash) do microcontrolador, garantindo que nenhum token já processado seja aceito novamente, independentemente de sua validade criptográfica (HAN; DU; LU, 2020).

Adicionalmente, Zhou et al. (2022) mapearam sistematicamente as vulnerabilidades introduzidas pelo paradigma *Mobile-as-a-Gateway* (MaaG), no qual o smartphone do usuário atua não como simples transportador, mas como árbitro ativo das políticas de acesso. Os autores identificaram quatro classes críticas de falha — perda semântica na tradução de permissões, responsabilidades assimétricas entre nuvem e dispositivo, inconsistência causal na sincronização e injeção de chaves ocultas locais — que permitem a usuários temporários manter acesso indefinido ao dispositivo físico mesmo após revogação no servidor. Esse diagnóstico fundamenta uma decisão arquitetural central no presente trabalho: o smartphone do corretor atua exclusivamente como transportador passivo do token assinado, sem poder de decisão ou armazenamento de regras de acesso; toda a lógica de validação reside no microcontrolador.

No plano das credenciais, o emprego de senhas estáticas ou padrões PIN perpetua vulnerabilidades de força bruta e captura por engenharia social (AUTHORS, 2024). Paralelamente, como advertem Silva, Samaniego e Deters (2023), a dependência irrestrita de serviços em nuvem proprietários de terceiros introduz o perigo de exfiltração não controlada de registros de acesso ou de indisponibilidade unilateral dos servidores remotos durante vistorias essenciais.

2.4.2 Mecanismos de Proteção e Trilhas de Auditoria

Para mitigar integralmente as fragilidades delineadas, a arquitetura do artefato adota uma estratégia de defesa em profundidade estruturada em quatro pilares técnicos complementares:

1. **Criptografia de Transporte (TLS):** Blindagem criptográfica fim a fim de todos os pacotes MQTT trafegados entre os clientes, o broker e o microcontrolador, inviabilizando técnicas de leitura e injeção maliciosa de pacotes (AMEER et al., 2022; AUTHORS, 2024).

2. **Descarte Temporal de Credenciais:** Configuração de expiração algorítmica estrita (TTL curto) associada a cada token gerado, eliminando os impactos de vazamento de credenciais pós-uso (SATANASAOWAPAK; MANASATHIEN; TREEBUPACHATSAKUL, 2021).

3. **Isolamento em Gateway Local:** Centralização da tomada de decisão no gateway de borda, preservando a fechadura contra conexões diretas oriundas da internet pública (VARDAKIS et al., 2024; AMEER et al., 2022).

4. **Trilha Auditável de Eventos (*Audit Trail*):** Persistência sequencial imutável de todos os eventos de autorização, abrangendo concessões legítimas, recusas de tentativas fora do expediente e revogações forçadas de acesso (AUTHORS, 2024).

A consolidação de logs auditáveis atende com rigor à necessidade de transparência demandada pela governança imobiliária: a qualquer instante, a administração dispõe de comprovação cabal de qual corretor solicitou a entrada, o instante exato de liberação e o tempo decorrido até o trancamento, estabelecendo a responsabilização inequívoca pelo patrimônio administrado.

Dessa forma, o conjunto de conceitos, protocolos e modelos analíticos delineados neste capítulo fornece o embasamento teórico e a justificativa técnica necessários para a formalização metodológica e o desenvolvimento do protótipo simulado nos capítulos subsequentes.

3 Metodologia de Pesquisa

Este capítulo descreve os procedimentos metodológicos adotados para a concepção, o desenvolvimento e a avaliação experimental do artefato proposto. O trabalho apoia-se nas diretrizes da *Design Science Research* (DSR), método voltado à resolução de problemas organizacionais mediante a criação e avaliação rigorosa de artefatos computacionais (HEVNER et al., 2004; PEFFERS et al., 2007).

3.1 Caracterização Metodológica

3.1.1 Design Science Research como Paradigma

A pesquisa em computação aplicada comporta abordagens explicativas e prescritivas. Enquanto as ciências comportamentais focam na observação de fenômenos, a DSR orienta-se pela produção de conhecimento por meio da construção e da validação empírica de artefatos — constructos, modelos, métodos e instanciações (HEVNER et al., 2004).

A gestão de visitas em imóveis desocupados apresenta gargalos operacionais e vulnerabilidades que decorrem de métodos manuais (chaves físicas e senhas estáticas) e da ausência de internet local nos imóveis. A resposta a essa demanda requer a especificação de modelos formais e a implementação de protótipos funcionais. A condução do estudo segue o modelo de processo de seis etapas estabelecido por Peffers et al. (2007), estruturado conforme o Quadro 3.

Tabela 3 – Mapeamento das etapas da Design Science Research no projeto.

Fase	**Etapa (PEFFERS et al., 2007)**	**Atividade Realizada**	**Localização**
1	Identificação do Problema	Diagnóstico das falhas de segurança e logística em imóveis vagos sem conectividade.	Seção 3.2 e Cap. 1
2	Definição dos Objetivos	Definição dos requisitos de projeto, pilares arquiteturais e metas quantitativas.	Seção 3.2.2 e Seção 3.3.3
3	Projeto e Desenvolvimento	Concepção do modelo HABACα, esquema Ed25519, firmware ESP32 e API FastAPI.	Cap. 4
4	Demonstração	Execução do fluxo nominal, testes negativos de ataque e revogação em bancada virtual.	Seção 3.3.2 e Cap. 4
5	Avaliação Experimental	Coleta de latência, memória e eficácia de bloqueio em 50 repetições com análise estatística.	Seção 3.3.3 e Cap. 4
6	Comunicação	Redação acadêmica, sistematização de diagramas e discussão comparativa dos dados.	Monografia

Fonte: Elaborado pelo autor (2026).

3.2 Contexto e Formalização do Problema

3.2.1 Cenário de Gestão de Visitas e Análise dos Métodos Vigentes

Imobiliárias administram carteiras distribuídas de unidades desocupadas cuja comercialização depende de corretores parceiros e prestadores de serviços. A operação caracteriza-se por três restrições: (i) ausência de conexão de rede local (Wi-Fi ou cabeada), visto que custos de banda larga não são mantidos na vacância; (ii) inexistência de fiscalização física no local; e (iii) elevada rotatividade de profissionais que necessitam de janelas de entrada temporárias e pontuais.

Conforme analisado no Quadro 1 (Seção 2.3.1), os métodos convencionais mostram-se inadequados: chaves metálicas causam atrito logístico e risco de cópias; cofres mecânicos empregam senhas estáticas compartilhadas sem rastreabilidade; e fechaduras comerciais conectadas dependem de Wi-Fi local ininterrupto, tornando-se inoperantes em imóveis desocupados.

3.2.2 Questão de Pesquisa e Pilares do Artefato

A incapacidade dos mecanismos atuais de conciliar operação desconectada, controle contextual e auditoria orienta a questão de pesquisa:

> *Como projetar e avaliar uma arquitetura de controle de acesso inteligente baseada em IoT capaz de gerenciar, de forma segura, rastreável e orientada a atributos (ABAC), o acesso temporário de múltiplos corretores parceiros a imóveis desocupados desprovidos de conexão à internet?*

Para orientar a construção do artefato, definiram-se quatro pilares técnicos:

1. **Independência de rede local (*Zero Local Infrastructure*):** Validação matemática de credenciais na borda sem consulta a servidores remotos e sem modems dedicados na fechadura.

2. **Autenticidade e não-repúdio:** Delegação assinada por autoridade central e vinculada ao dispositivo móvel habilitado do corretor.

3. **Autorização orientada a atributos (ABAC):** Liberação condicionada a atributos de sujeito, objeto, ação e ambiente avaliados em tempo de execução.

4. **Auditoria assíncrona:** Registro inviolável de acessos e sincronização com a nuvem utilizando o smartphone do corretor como portador de dados (*data mule*).

3.3 Procedimentos e Instrumentos de Avaliação

3.3.1 Ambiente de Simulação Virtual

A avaliação do artefato adota a simulação virtual no Wokwi Simulator (RESEARCHERS, 2024). A opção justifica-se por três fatores: (i) reprodutibilidade científica integral dos ensaios de temporização em ambiente controlado; (ii) isolamento de variáveis espúrias mecânicas ou térmicas de protoboards na medição da computação criptográfica; e (iii) viabilidade experimental de testes de estresse sem degradação física de atuadores solenoide.

3.3.2 Planejamento dos Cenários de Demonstração

A validação funcional divide-se em três cenários planejados: **Cenário 1 (Fluxo nominal):** Avalia a solicitação de token por corretor cadastrado para imóvel liberado em horário comercial. Critério de sucesso: emissão do token, validação no microcontrolador em menos de 10 ms, acionamento do relé por 5 segundos e entrega do recibo de telemetria via MQTT sob QoS 1.

Cenário 2 (Ensaios negativos e ataques): Avalia a capacidade de rejeição local do firmware frente a credenciais anômalas, de acordo com o planejamento do Quadro 4. Critério de aceitação: índice de 100% de bloqueio efetivo sem concessões indevidas.

Tabela 4 – Planejamento dos ensaios de segurança do Cenário 2.

Caso	Condição Testada	Estímulo Aplicado	Comportamento Esperado
CT-2.1	Token Expirado	Credencial autêntica com timestamp posterior ao campo `exp`.	Rejeição por TTL estourado e LED vermelho.
CT-2.2	Imóvel Incorreto	Token emitido para a unidade A apresentado na unidade B.	Bloqueio por divergência no campo `dev`.
CT-2.3	Assinatura Corrompida	Adulteração intencional de 1 bit no conteúdo do payload JSON.	Falha na verificação Ed25519 e descarte.
CT-2.4	Ataque de Repetição	Reenvio de credencial já consumida em momento anterior.	Bloqueio por identificador `jti` no buffer NVS.

Fonte: Elaborado pelo autor (2026).

Cenário 3 (Revogação e risco residual): Avalia a resposta do sistema diante da suspensão cadastral de um corretor. O plano verifica a imediata recusa de novas emissões pelo servidor (HTTP 403) e a contenção no nó desconectado por tempo de vida estrito (*Time-To-Live* de 15 minutos) para tokens emitidos previamente.

3.3.3 Métricas Quantitativas e Tratamento Estatístico

Para a avaliação empírica do artefato, definiram-se oito métricas quantitativas com base na literatura de IoT (AMEER et al., 2022; VARDAKIS et al., 2024; RESEARCHERS, 2024), sintetizadas no Quadro 5.

Tabela 5 – Métricas quantitativas planejadas para a avaliação experimental.

#	**Métrica**	**Unid.**	**Instrumento e Coleta**	**Meta**
M1	Latência de Decisão ABAC	ms	Medição de tempo de processamento no PDP FastAPI.	$<$ 50 ms
M2	Tempo de Assinatura Criptográfica	ms	Medição interna da biblioteca PyNaCl (Ed25519).	$<$ 5 ms
M3	Verificação no ESP32	ms	Temporização via função `micros()` no firmware.	$<$ 10 ms
M4	Latência Ponta a Ponta	ms	Intervalo entre requisição móvel e acionamento do relé.	$<$ 500 ms
M5	Consumo de Memória RAM Heap	KB	Amostragem via rotina nativa `ESP.getFreeHeap()`.	$<$ 120 KB
M6	Ocupação de Memória Flash	%	Relatório de vinculação estática do PlatformIO.	$<$ 35%
M7	Vazão de Mensagens MQTT	msg/s	Teste de estresse de publicações com Locust.	$>$ 100 msg/s
M8	Taxa de Bloqueio de Ataques	%	Percentual de rejeição nos testes CT-2.1 a CT-2.4.	100%

Fonte: Elaborado pelo autor (2026).

O procedimento experimental prevê 50 repetições para cada medição temporal, reduzindo perturbações estatísticas. Os dados a serem coletados nas baterias de testes serão tratados estatisticamente com as bibliotecas Pandas e SciPy, apurando média (μ), desvio padrão (σ), valores extremos e os percentis $p50$, $p95$ e $p99$. Os resultados esperados e o detalhamento analítico do artefato constam no Capítulo 4.

4 Concepção do Artefato e Resultados Esperados

Este capítulo apresenta a especificação técnica do artefato desenvolvido no escopo desta pesquisa e a projeção dos resultados esperados para sua validação experimental. No paradigma da *Design Science Research* (DSR), a própria modelagem formal e a arquitetura da solução constituem resultados essenciais de projeto (Fase 3 – Concepção e Desenvolvimento). Inicialmente, descrevem-se a visão arquitetural em camadas, o modelo de autorização contextual (ABAC), o esquema criptográfico assimétrico para validação offline, o fluxo operacional ponta a ponta e a pilha tecnológica do sistema. Em seguida, estabelecem-se os comportamentos esperados nos cenários de demonstração (Fase 4) e a sistematização das metas quantitativas que nortearão a avaliação experimental do protótipo (Fase 5), confrontando as hipóteses de desempenho com a literatura correlata.

4.1 Arquitetura Geral do Artefato Desenvolvido

4.1.1 Visão em Camadas do Ecossistema IoT

Em conformidade com a taxonomia de sistemas IoT apresentada por Vardakis et al. (2024), a arquitetura do artefato estrutura-se em quatro camadas funcionais e físicas delimitadas:

1. **Camada de Aplicação e Gestão:** Abriga o painel administrativo da imobiliária (configuração de políticas e gestão cadastral) e o aplicativo móvel do corretor (solicitação de acesso e exibição de credenciais).

2. **Camada de Serviço e Decisão:** Executada em ambiente de computação em nuvem, centraliza o motor de inferência ABAC (*Attribute-Based Access Control*), o módulo de assinatura criptográfica e o *broker* de mensageria para ingestão de eventos.

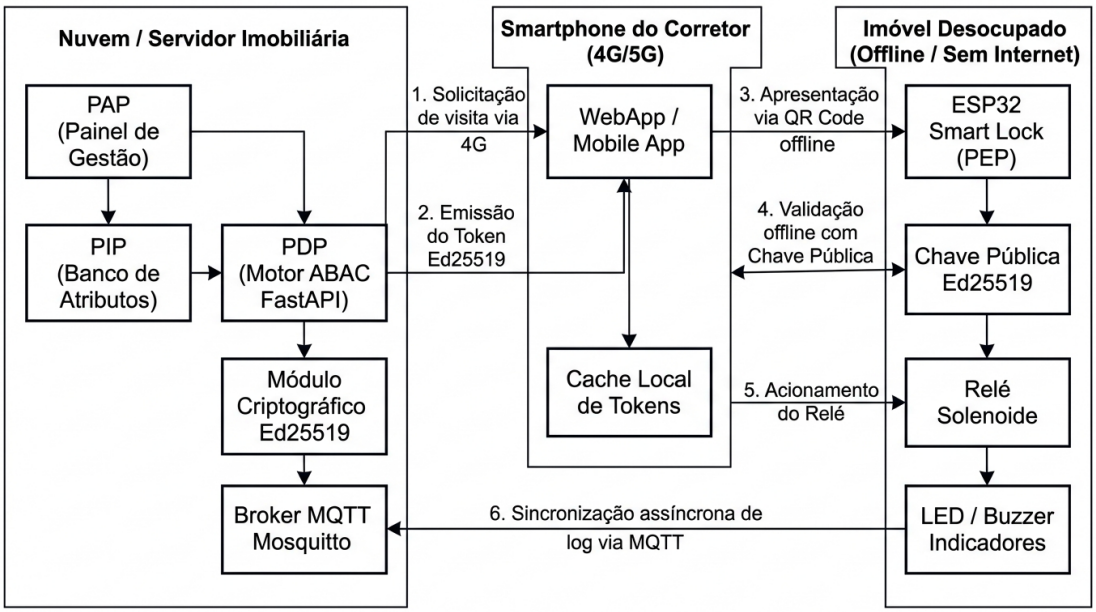
3. **Camada de Rede e Transporte:** Abrange os protocolos de comunicação do sistema, compreendendo conexões celulares 4G/5G (HTTPS/REST) entre o aplicativo móvel e a nuvem, o canal desconectado por leitura óptica (QR Code) entre smartphone e fechadura, e o protocolo MQTT (*Message Queuing Telemetry Transport*) sob QoS 1 para transporte de auditoria.

4. **Camada Física e de Percepção:** Reúne o microcontrolador ESP32 posicionado na porta do imóvel, o relé que comanda a trava solenoide, os atuadores de sinalização (LED e *buzzer*) e a interface de leitura responsável pela captura do payload serial.

4.1.2 Componentes Arquiteturais e Domínios do Sistema

A Figura 1 ilustra a topologia geral do sistema, evidenciando o desacoplamento entre a infraestrutura central de decisão em nuvem e a unidade de execução local instalada no imóvel.

Figura 1 – Visão geral da arquitetura do artefato IoT em ambiente desconectado.



Fonte: Elaborado pelo autor (2026).

O ecossistema divide-se em três domínios físicos com responsabilidades bem delimitadas:

- **Nuvem da Imobiliária:** Centraliza os serviços corporativos e a tomada de decisão. Contém o Painel de Gestão (*Policy Administration Point* – PAP), o repositório de atributos cadastrais (*Policy Information Point* – PIP), o motor de regras (*Policy Decision Point* – PDP em FastAPI), o módulo criptográfico detentor da chave privada Ed25519 e o broker MQTT (Eclipse Mosquitto) para recepção das telemetrias de auditoria.
- **Smartphone do Corretor:** Atua como elemento intermediário e portador (*data mule/carrier*) de credenciais e telemetrias. Uma vez que o profissional dispõe de conectividade celular móvel (4G/5G), seu smartphone estabelece a ponte de comunicação entre a nuvem e o imóvel desocupado, requisitando o token pela internet e apresentando-o localmente por leitura óptica.
- **Nó da Fechadura (ESP32):** Atua como Ponto de Aplicação de Políticas (*Policy Enforcement Point* – PEP) local. Opera em regime estritamente desconectado (*zero local infrastructure*), desprovido de conexão Wi-Fi ou modem celular. Armazena exclusivamente a chave pública da autoridade emissora em memória permanente protegida, garantindo que mesmo o acesso físico ao hardware não exponha segredos capazes de forjar credenciais.

O ciclo operacional entre esses domínios executa-se em seis etapas: (1) solicitação de visita via canal celular 4G/5G pelo aplicativo móvel; (2) avaliação de políticas no PDP e assinatura digital do token com a chave privada mestre Ed25519; (3) renderização da credencial em código QR dinâmico na tela do smartphone; (4) verificação determinística da assinatura no microcontrolador ESP32 contra a chave pública gravada no firmware; (5) comutação do relé por 5 segundos para retração do solenoide acompanhada de sinalização visual e sonora; e (6) despacho assíncrono do recibo de confirmação ao broker MQTT via smartphone sob QoS 1 (*at least once*).

4.2 Modelo de Autorização Baseado em Atributos (ABAC)

4.2.1 Transição do RBAC ao ABAC no Contexto Imobiliário

O modelo de Controle de Acesso Baseado em Papéis (*Role-Based Access Control* – RBAC) restringe privilégios a partir de funções estáticas atribuídas a usuários. No cenário imobiliário, essa abordagem mostra-se insuficiente: determinar apenas que um indivíduo possui o papel de "corretor" não impede que ele ingresse na propriedade fora do horário comercial, acesse unidades vendidas ou entre em imóveis sem agendamento homologado. Tentar contornar essas limitações via RBAC gera explosão de papéis (*role explosion*), tornando a administração impraticável.

O Controle de Acesso Baseado em Atributos (*Attribute-Based Access Control* – ABAC), adaptado da formulação HABACα proposta por Ameer et al. (2022), soluciona essa restrição avaliando dinamicamente predicados lógicos em tempo de execução:

$$\text{Decisão} = f(U_{\text{atrib}},\ D_{\text{atrib}},\ OP_{\text{atrib}},\ ES_{\text{atrib}}) \tag{4.1}$$

Em que U_{atrib} representa os atributos do sujeito solicitante, D_{atrib} os atributos do dispositivo/imóvel de destino, OP_{atrib} os parâmetros da ação requerida e ES_{atrib} as variáveis contextuais do ambiente no instante da avaliação.

4.2.2 Dicionário de Atributos do Sistema

O modelo formal implementado organiza treze atributos essenciais para a regulação do acesso às unidades, detalhados no Quadro 6.

4.2.3 Arquitetura Funcional segundo o Padrão NIST SP 800-162

A segregação dos módulos de controle de acesso adota as especificações do padrão NIST SP 800-162, dividindo as responsabilidades de administração, persistência, inferência e aplicação, conforme exposto na Figura 2.

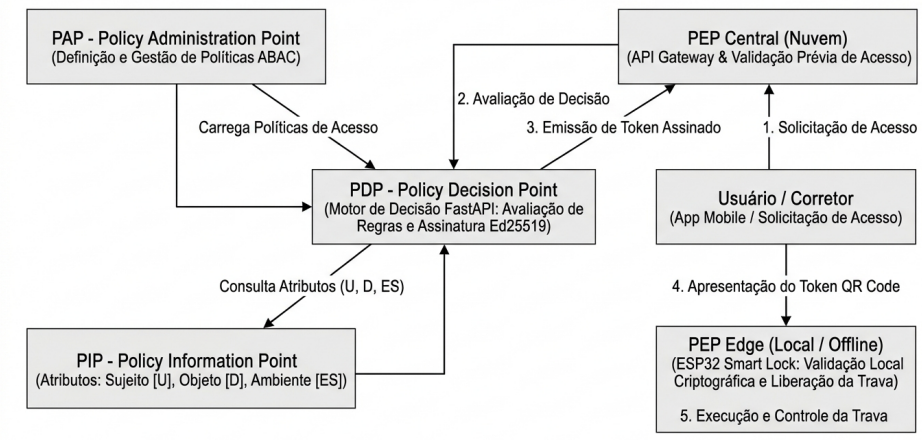
A interação entre os módulos ocorre de maneira estruturada:

Tabela 6 – Dicionário de atributos do modelo ABAC implementado.

Entidade	Símbolo	Atributo	Definição e Tipagem
Sujeito (U)	U	`u.id`	String (UUID): Identificador único do corretor.
	U	`u.role`	Enum: `CORRETOR_PARCEIRO`, `GESTOR`.
	U	`u.status`	Enum: `ATIVO`, `SUSPENSO`, `PENDENTE`.
	U	`u.device_fp`	String (Hash SHA-256): Identificador do smartphone cadastrado.
Objeto (D)	D	`d.lock_id`	String (Hex): Identificador físico gravado no ESP32.
	D	`d.status_imovel`	Enum: `DISPONIVEL_VENDA`, `LOCADO`, `MANUTENCAO`.
	D	`d.lock_state`	Enum: `TRAVADO`, `DESTRAVADO`, `BLOQUEIO`.
Ação (OP)	OP	`op.tipo`	Enum: `SOLICITAR_TOKEN`, `DESTRAVAR_PORTA`.
	OP	`op.modo`	Enum: `OFFLINE_BEARER`, `TELEMETRIA`.
Ambiente (ES)	ES	`es.timestamp`	Inteiro (Unix Epoch): Horário de recepção da solicitação.
	ES	`es.horario_comercial`	Booleano: `true` se horário atual estiver entre 08h e 19h.
	ES	`es.dia_permitido`	Booleano: Restrição a finais de semana ou feriados.
	ES	`es.agendamento_ativo`	Booleano: Confirmação de visita agendada na base imobiliária.

Fonte: Elaborado pelo autor (2026).

Figura 2 – Arquitetura funcional de controle de acesso ABAC baseada no padrão NIST SP 800-162.



Fonte: Elaborado pelo autor (2026).

- **PAP (*Policy Administration Point*):** Módulo administrativo em que gestores definem e atualizam as regras de visitação e horários permitidos.
- **PIP (*Policy Information Point*):** Base relacional estruturada que fornece os valores correntes dos atributos vinculados ao usuário, à unidade imobiliária e à agenda.
- **PDP (*Policy Decision Point*):** Motor de inferência construído sobre FastAPI/Python. Processa os dados da requisição, consulta o PIP, confronta as condições estipuladas na política e comanda o módulo criptográfico para emissão do token.
- **PEP Central (*Cloud PEP*):** Ponto de aplicação no API Gateway de nuvem, responsável por barrar requisições malformadas ou com falha de autenticação preliminar.
- **PEP Borda (*Edge PEP*):** Firmware embarcado no ESP32 na porta do imóvel. Recebe a credencial, checa a assinatura digital contra a chave pública e comuta o relé físico.

4.2.4 Formalização das Regras de Acesso e Algoritmo de Combinação

As políticas de acesso são estruturadas em formato JSON e avaliadas pelo PDP. O Código 4.1 apresenta a regra fundamental aplicada às visitas de corretores parceiros.

Listing 4.1 – Estrutura da política de autorização ABAC implementada no PDP.

```
{
  "policy_id": "POL_VISITA_IMOVEL_DISPONIVEL",
  "description": "Permite visita de corretores ativos a imoveis disponiveis em
      horario comercial",
  "target": {
    "action": "SOLICITAR_TOKEN",
    "role": "CORRETOR_PARCEIRO"
  },
  "rules": [
    {
      "rule_id": "REGRA_01_STATUS_CORRETOR",
      "condition": "u.status == 'ATIVO'",
      "effect": "Permit"
    },
    {
      "rule_id": "REGRA_02_STATUS_IMOVEL",
      "condition": "d.status_imovel in ['DISPONIVEL_VENDA', 'DISPONIVEL_LOCACAO']",
      "effect": "Permit"
    },
    {
      "rule_id": "REGRA_03_JANELA_HORARIA",
      "condition": "es.horario_comercial == true and es.dia_permitido == true",
      "effect": "Permit"
    },
```

```
24      {
25        "rule_id": "REGRA_04_VINCULO_AGENDAMENTO",
26        "condition": "es.agendamento_ativo == true",
27        "effect": "Permit"
28      }
29    ],
30    "rule_combining_algorithm": "deny_overrides"
31  }
```

O mecanismo adota a disciplina de combinação `deny_overrides`: caso qualquer uma das regras retorne negação (*Deny*), a requisição é sumariamente recusada pelo servidor, aplicando com rigor o princípio do privilégio mínimo.

4.3 Modelo Criptográfico e Validação Offline

4.3.1 O Paradigma da Validação Desconectada (Analogia EMV)

O nó IoT instalado na porta opera sem conexão à internet no instante em que o corretor se apresenta no local. A concepção adotada baseia-se no princípio empregado pelo padrão bancário internacional EMV (*Europay, Mastercard, Visa*) para transações em terminais desconectados (*offline transaction verification*).

No padrão EMV, o terminal de pagamento não consulta o saldo em conta em tempo real, mas possui gravada a chave pública da autoridade emissora. Ao validar a assinatura digital contida no microprocessador do cartão, o terminal obtém garantia matemática de autenticidade da credencial e integridade dos dados da operação.

No artefato desenvolvido, o PDP na nuvem desempenha o papel de autoridade emissora, detendo a chave privada mestre. O smartphone atua como portador do token assinado. O microcontrolador ESP32 comporta-se de forma análoga ao terminal: a partir da chave pública armazenada em sua memória, autentica o token apresentado localmente sem recorrer a redes externas.

4.3.2 Seleção do Algoritmo Criptográfico Ed25519

Microcontroladores de baixo consumo operam sob fortes restrições de memória volátil e capacidade aritmética. Algoritmos assimétricos tradicionais, como RSA-2048, exigem exponenciação modular pesada, demandando elevado tempo de processamento e consumo de memória RAM incompatível com o ESP32.

A criptografia de curvas elípticas contorna essa restrição. O algoritmo selecionado para o projeto foi o Ed25519 (*Edwards-curve Digital Signature Algorithm*), baseado na Curva de Edwards Torcida Curve25519. O Quadro 7 compara as características técnicas de esquemas comuns frente às demandas do nó embarcado.

Tabela 7 – Comparativo entre esquemas criptográficos para validação em nós IoT embarcados.

Critério	**RSA-2048**	**HMAC-SHA256**	**Ed25519**	**Impacto no ESP32**
Tipo de Chave	Assimétrica	Simétrica	Assimétrica	Protege contra cópia física da memória Flash.
Tamanho da Chave	256 bytes	32 bytes (segredo)	32 bytes	Reduzida ocupação em memória permanente.
Tamanho da Assinatura	256 bytes	32 bytes	64 bytes	Otimizado para pacotes seriais e códigos QR.
Tempo de Verificação	150 a 300 ms	< 1 ms	1,8 a 3,5 ms	Desempenho quase instantâneo de abertura.
Nível de Segurança	112 bits	128 bits	128 bits	Criptograficamente equivalente a RSA de 3072 bits.
Ataques de Canal Lateral	Moderada	Boa	Excelente	Imunidade a variações de tempo computacional.

Fonte: Elaborado pelo autor com base em Ameer et al. (2022) e dados de literatura técnica (2026).

A adoção do Ed25519 oferece uma vantagem estrutural: como o microcontrolador armazena exclusivamente a chave pública (32 bytes), mesmo que o equipamento seja subtraído fisicamente e sua memória extraída, nenhuma chave privada é comprometida, impedindo a geração forjada de credenciais para outras unidades.

4.3.3 Estrutura do Token de Acesso

O token emitido pelo PDP é compactado em formato serializado JSON. O Código 4.2 ilustra a estrutura dos campos transmitidos.

Listing 4.2 – Estrutura formal do payload do token de acesso emitido pelo PDP.

```
{
  "jti": "a7f4b892-91c2-4e88-9d21-f09b578c92a1",
  "sub": "corretor_id_8472",
  "dev": "lock_esp32_imovel_042",
  "nbf": 1774204800,
  "exp": 1774205700,
  "act": "UNLOCK_DOOR",
  "fp": "e3b0c442...[hash SHA-256 do aparelho]...",
  "sig": "3a8f9c10...[64 bytes assinatura Ed25519]..."
}
```

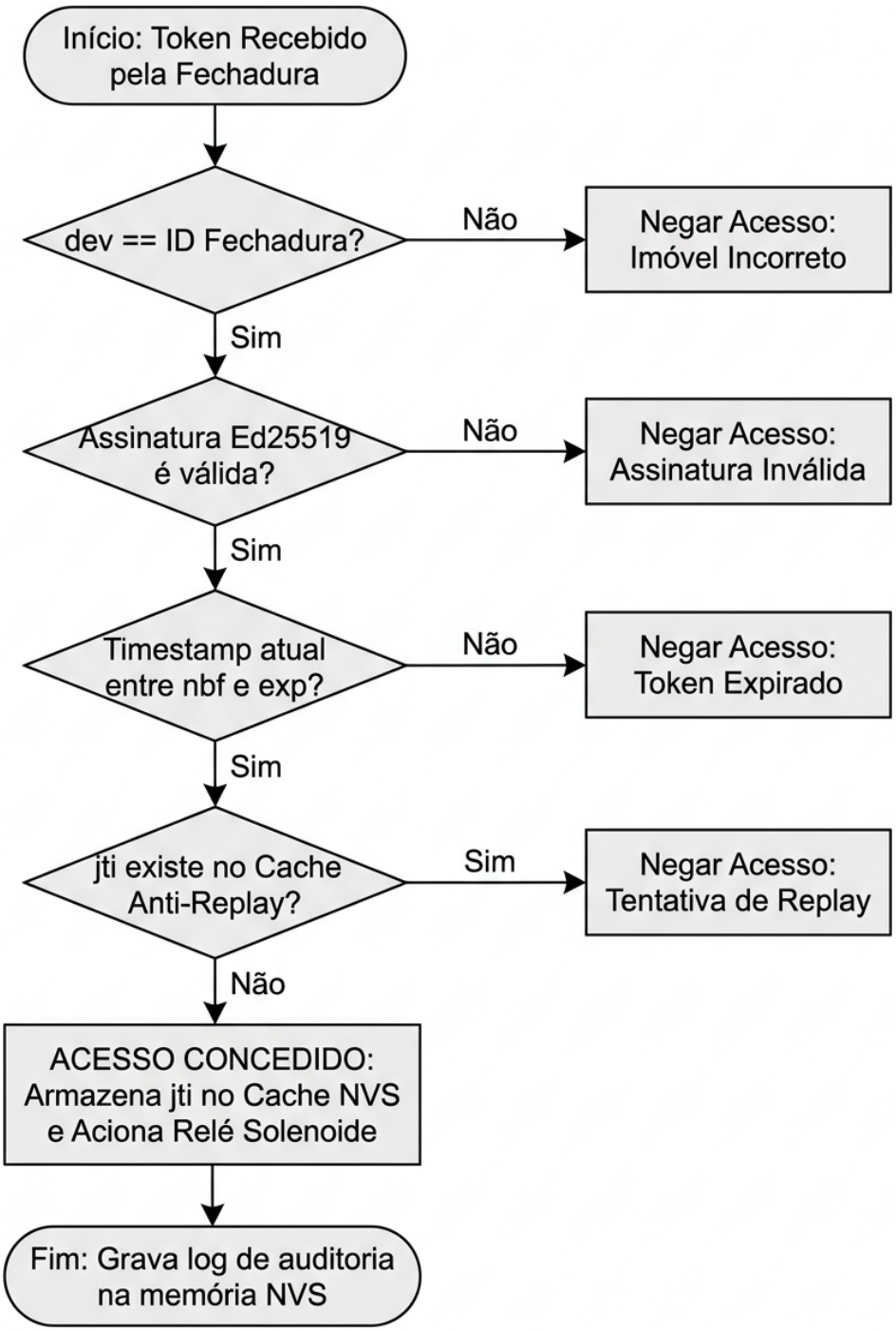
O detalhamento funcional de cada parâmetro constituinte consta no Quadro 8.

4.3.4 Algoritmo de Verificação Local no ESP32

Ao receber o payload serial via interface de leitura, o firmware do ESP32 processa os dados por meio de uma bateria determinística de cinco testes, conforme sumarizado na Figura 3.

O fluxo executa-se com término antecipado ao menor indício de inconsistência:

Figura 3 – Fluxograma de validação determinística de tokens offline no microcontrolador ESP32.



Fonte: Elaborado pelo autor (2026).

Tabela 8 – Dicionário de campos constituintes do token de acesso.

Campo	Nome Técnico	Finalidade Funcional
`jti`	JWT ID / Nonce	Identificador universal único (UUIDv4) para prevenção de ataques de repetição.
`sub`	*Subject*	Identificador cadastral do corretor requerente habilitado.
`dev`	*Device Target*	Identificador exclusivo da fechadura destinatária. Evita o uso em portas incorretas.
`nbf`	*Not Before*	Timestamp Unix que estabelece o início da validade da permissão concedida.
`exp`	*Expiration*	Timestamp Unix final de vigência (tempo de vida restrito a 15 minutos).
`act`	*Action*	Ação delegada ao dispositivo físico (`UNLOCK_DOOR`).
`fp`	*Device Fingerprint*	Hash vinculado ao aparelho móvel cadastrado (SATANASAOWAPAK; MANASATHIEN; TREEBUPACHATSAKUL, 2021).
`sig`	*Digital Signature*	Assinatura de 64 bytes gerada pelo PDP com a chave privada mestre Ed25519.

Fonte: Elaborado pelo autor (2026).

1. **Verificação de Destino (`dev`):** Compara o campo `dev` com a identidade física da fechadura gravada na partição de configuração.
2. **Verificação Criptográfica (`sig`):** Invoca a biblioteca `mbedtls` para recalcular a verificação assimétrica da assinatura com a chave pública mestre.
3. **Verificação Temporal (`nbf` e `exp`):** Compara o horário interno com a janela permitida.
4. **Verificação de Unicidade (`jti`):** Consulta a partição NVS para checar se o token já foi consumido.
5. **Atuação Mecânica:** Persiste o `jti` no buffer histórico, aciona o relé por 5 segundos e ativa a sinalização audiovisual.

4.3.5 Prevenção contra Ataques e Gestão do Buffer Anti-Replay

Para assegurar que interceptações não permitam aberturas indevidas, o sistema projeta as contramedidas estruturadas no Quadro 9.

A gestão do buffer anti-replay dimensiona uma fila circular na memória flash NVS com capacidade para reter até 200 identificadores `jti`. Com validade restrita a 15 minutos (900 segundos) por token, o buffer de 200 posições atende com margem à rotina de visitas, ocupando menos de 8 KB na partição de dados.

4.4 Fluxo de Operação de Ponta a Ponta

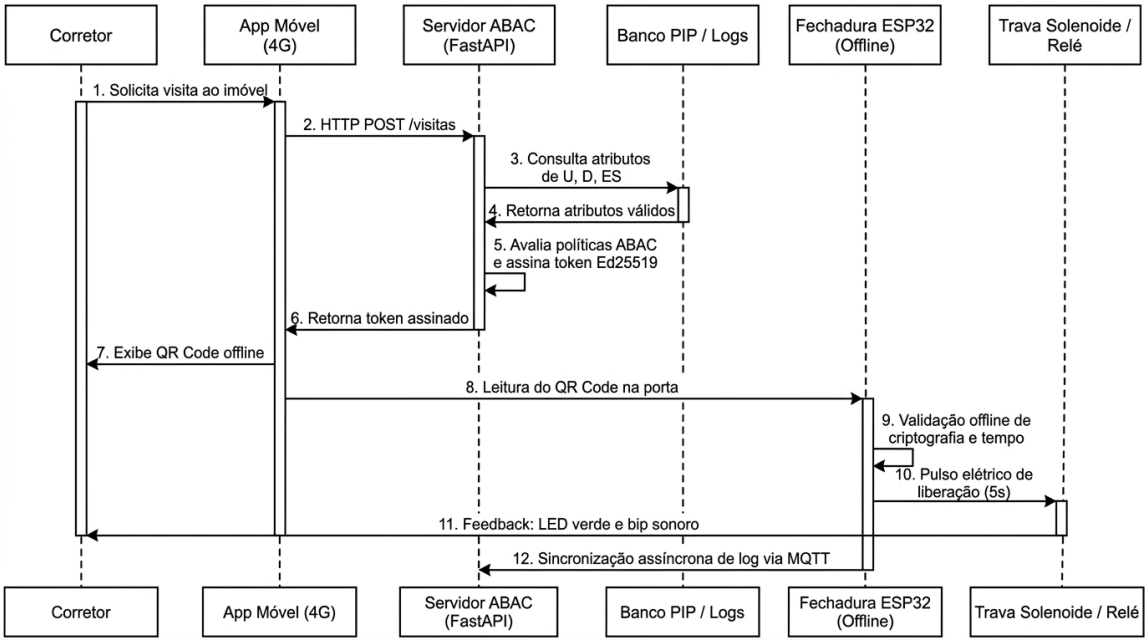
A operação do ecossistema divide-se em três etapas coordenadas: emissão online do token pela nuvem, validação local offline no imóvel e sincronização assíncrona de auditoria. A Figura 4 expõe o diagrama de sequência detalhado.

Tabela 9 – Matriz de contramedidas de segurança projetadas contra vetores de ataque.

Vetor de Ataque	**Descrição do Ataque**	**Mecanismo de Defesa do Artefato**
Replay Attack	Interceptação do código QR para reapresentação posterior ao leitor.	O `jti` é gravado em buffer circular na memória Flash NVS. Reenvios são barrados.
Token Expirado	Uso de credencial legítima após o horário autorizado.	Confronto do timestamp `exp` com descarte de tokens com TTL estourado.
Adulteração de Payload	Tentativa de forjar horário de término ou trocar identificador de imóvel.	A assinatura Ed25519 é invalidada matematicamente; leitura é recusada.
Imóvel Incorreto	Uso de token da Unidade A na Unidade B.	O identificador `dev` diverge da identidade estática da fechadura.
Compartilhamento	Envio de captura de tela para terceiro não credenciado.	O hash `fp` vincula o token ao smartphone registrado (SATANASAOWAPAK; MANASATHIEN; TREEBUPACHATSAKUL, 2021).
Subtração do Nó	Furto físico do dispositivo para clonagem de chaves.	O microcontrolador guarda apenas a chave pública; chaves privadas ficam isoladas na nuvem.

Fonte: Elaborado pelo autor (2026).

Figura 4 – Diagrama de sequência ponta a ponta do processo de requisição, validação e auditoria de visitas.



Fonte: Elaborado pelo autor (2026).

4.4.1 Fase 1: Solicitação e Emissão do Token (Online)

1. Ao se aproximar do imóvel, o corretor aciona o aplicativo em seu smartphone conectado à rede celular (4G/5G).
2. O aplicativo envia uma requisição HTTP via TLS pelo endpoint `</api/v1/access/request-token>` ao servidor central, informando suas credenciais, identificador do imóvel e assinatura digital do aparelho móvel.
3. O PDP recebe a requisição e interroga o banco relacional (PIP) para obter a situação cadastral do corretor, regras do condomínio e agendamento ativo.
4. O motor ABAC processa as condições declaradas na política ativa.
5. Havendo conformidade, o módulo criptográfico gera o payload com identificador `jti` inédito, calcula a assinatura digital com a chave privada mestre Ed25519 e devolve o pacote codificado em JSON sob código HTTP 200. Havendo inconformidade, o servidor devolve código HTTP 403 com a justificativa de negação.
6. O aplicativo retém a credencial em cache seguro e gera na tela um código QR dinâmico com o payload serializado.

4.4.2 Fase 2: Apresentação e Validação Local (Offline)

1. O corretor aproxima a tela do smartphone da interface de leitura associada ao microcontrolador ESP32 na porta do imóvel.
2. O microcontrolador processa a cadeia de caracteres recebida e reconstrói o payload em memória de trabalho.
3. O firmware executa a rotina de validação: confere o código `dev`, verifica a assinatura Ed25519 com a chave pública instalada, atesta a janela de vigência (`nbf` e `exp`) e busca o `jti` no buffer anti-replay.
4. Comprovada a autenticidade e tempestividade do token, o pino GPIO 23 é levado a nível lógico alto, excitando a bobina do relé por 5 segundos para retração do pino solenoide. Concomitantemente, o LED verde (GPIO 2) acende e o *buzzer* (GPIO 18) emite um sinal agudo.
5. O identificador `jti` é gravado na memória Flash NVS local.

4.4.3 Fase 3: Sincronização Assíncrona e Auditoria

1. Concluída a abertura física, o aplicativo do corretor gera um recibo assinado contendo o `jti` consumido e o timestamp da operação.

2. O smartphone despacha o recibo ao broker MQTT corporativo (Eclipse Mosquitto) no canal `imobiliaria/auditoria/acessos`, via conexão celular e nível de serviço QoS 1 (*at least once*).

3. O serviço de auditoria em nuvem armazena a mensagem na base relacional da imobiliária, garantindo rastreabilidade sem violar o isolamento do nó físico.

4.5 Stack Tecnológica e Especificação do Firmware

4.5.1 Mapeamento dos Componentes Tecnológicos

A escolha das ferramentas orientou-se pela padronização acadêmica e viabilidade de execução em sistemas embarcados restritos. O Quadro 10 sintetiza os componentes da solução.

Tabela 10 – Mapeamento da pilha tecnológica empregada no desenvolvimento do artefato.

Camada / Módulo	**Tecnologia Selecionada**	**Justificativa Técnica e Acadêmica**
Nó da Fechadura (PEP)	ESP32 DevKit v1 (Xtensa LX6 Dual-Core 240 MHz)	Plataforma consolidada na literatura de automação e segurança IoT residencial (VARDAKIS et al., 2024).
Linguagem do Firmware	C/C++ sobre PlatformIO / Framework Arduino	Controle determinístico de memória e integração nativa à biblioteca criptográfica `mbedtls`.
Servidor de Políticas (PDP)	Python 3.11+ com FastAPI	Arquitetura assíncrona ASGI de alto rendimento, tipagem estrita com Pydantic e documentação OpenAPI.
Biblioteca Criptográfica	PyNaCl (Servidor) e mbedtls (ESP32)	Implementações de referência do algoritmo Ed25519 resistentes a vazamento por canal lateral.
Broker de Mensageria	Eclipse Mosquitto v2.0+	Padrão aberto com suporte nativo a MQTT v3.1.1/v5.0, baixo consumo de memória ($<$ 10 MB) e garantia QoS 1.
Ambiente de Simulação	Wokwi IoT Simulator	Plataforma com emulação precisa de registradores do ESP32, suporte a rede virtual e periféricos.
Interface do Corretor	Progressive Web App (PWA) em HTML5/JS	Permite acesso multiplataforma via navegador móvel sem fricção de distribuição em lojas de aplicativos.
Ferramentas de Carga	Locust e Pytest	Automação de testes de estresse, injeção de requisições concorrentes e mensuração de latências.

Fonte: Elaborado pelo autor (2026).

4.5.2 Organização Modular do Firmware no ESP32

O software a ser embarcado no microcontrolador organiza-se em três módulos desacoplados:

`crypto_verifier.cpp`: Isola o subsistema criptográfico. Contém a chave pública mestre de 32 bytes (`SERVER_PUBLIC_KEY`) gravada em memória de programa (`PROGMEM`). Inicializa as estruturas da biblioteca `mbedtls` e disponibiliza a função `verify_ed25519_signature(payload, signature, pubkey)`.

`token_validator.cpp`: Executa a análise semântica dos dados recebidos. Utiliza a biblioteca `ArduinoJson` com alocação estática de memória (`StaticJsonDocument`) para prevenir fragmentação de heap. Realiza o confronto do campo `dev`, checagem de janelas temporais e iteração sobre a lista anti-replay mantida na NVS.

`lock_actuator.cpp`: Gerencia a interface com atuadores e sinalizadores físicos. Controla os estados dos pinos GPIO por temporizadores não bloqueantes baseados na função `millis()`, eliminando bloqueios de processamento.

4.5.3 Endpoints e Motor de Inferência em FastAPI

O backend construído sobre FastAPI disponibiliza três pontos de entrada principais:

- `POST /api/v1/access/request-token`: Endpoint principal de requisição. Recebe as credenciais do corretor, ID do imóvel e dados contextuais. Aciona a função de inferência ABAC, consulta a base relacional e, havendo decisão afirmativa, emprega o método `crypto_sign_detached` da biblioteca `PyNaCl` para produzir a assinatura do token.
- `PATCH /api/v1/corretores/{id}/status`: Ponto de gestão cadastral utilizado por administradores. Permite alterar o status de um corretor de `ATIVO` para `SUSPENSO`. Modificações refletem-se instantaneamente no banco relacional, bloqueando emissões subsequentes de tokens.
- `GET /api/v1/imoveis/{id}/logs`: Consulta a série histórica de acessos registrados para uma determinada unidade imobiliária, viabilizando relatórios gerenciais de auditoria.

4.5.4 Estrutura de Mensageria e Tópicos MQTT

Para garantir a rastreabilidade dos eventos, as mensagens transitam pelo broker Eclipse Mosquitto estruturadas sob uma hierarquia padronizada de tópicos:

Listing 4.3 – Estrutura hierárquica de tópicos MQTT empregada no sistema.

```
1  imobiliaria/
2  +-- imoveis/{imovel_id}/
3  |   +-- status        # Telemetria: Online/Offline/Bateria
4  |   +-- revogacoes    # Broadcast de revogacao emergencial
5  |   +-- telemetria    # Tempo de resposta e diagnosticos
6  +-- auditoria/
7  |   +-- acessos       # Recibos de acessos executados
8  |   +-- alertas       # Tentativas com token invalido
9  +-- comandos/{imovel_id}/
10     +-- emergencia    # Bloqueio forcado administrativo
```

O pacote de auditoria remetido ao canal `imobiliaria/auditoria/acessos` adota a estrutura esquemática apresentada no Código 4.4.

Listing 4.4 – Formato esquemático do pacote de auditoria despachado via MQTT QoS 1.

```
{
  "event_id": "evt_998124_ack",
  "timestamp": 1774204850,
  "imovel_id": "lock_esp32_imovel_042",
  "corretor_id": "corretor_id_8472",
  "jti_utilizado": "a7f4b892-91c2-4e88-9d21-f09b578c92a1",
  "resultado": "ACESSO_CONCEDIDO",
  "latencia_validacao_ms": 2.45,
  "latencia_comunicacao_ms": 178.30
}
```

4.6 Bancada de Simulação Virtual no Wokwi

4.6.1 Mapeamento do Circuito Eletrônico e Pinout

O circuito virtual foi modelado no Wokwi Simulator utilizando o módulo virtual ESP32 DevKit v1. As ligações elétricas aos periféricos virtuais utilizam o mapa de pinos indicado no Quadro 11.

Tabela 11 – Mapeamento dos pinos GPIO e periféricos no circuito virtual ESP32.

Pino GPIO	Direção	Dispositivo Conectado	Comportamento e Função
GPIO 23	Saída (Digital)	Módulo Relé Solenoide	Nível ALTO comuta o relé por 5 segundos para liberar a trava.
GPIO 2	Saída (Digital)	LED Verde	Pulso luminoso que indica validação e liberação do acesso.
GPIO 4	Saída (Digital)	LED Vermelho	Sinaliza rejeição (token inválido, expirado ou unidade divergente).
GPIO 18	Saída (PWM)	Buzzer Piezoelétrico	Emite um tom agudo para sucesso e dois graves para rejeição.
GPIO 16 / 17	Entrada/Saída	Porta Serial / Leitor RX/TX	Recepção dos dados brutos correspondentes à leitura do código.

Fonte: Elaborado pelo autor (2026).

A topologia das conexões entre pinos, componentes e referências de terra (GND) é parametrizada no arquivo descritivo `diagram.json`, reproduzido no Código 4.5.

Listing 4.5 – Arquivo descritivo diagram.json do circuito virtual no simulador Wokwi.

```
{
  "version": 1,
  "author": "Controle de Acesso IoT - TCC",
  "editor": "wokwi",
  "parts": [
    { "type": "wokwi-esp32-devkit-v1", "id": "esp", "top": 0, "left": 0, "attrs": {}
        },
```

```
7     { "type": "wokwi-relay-module", "id": "relay", "top": 100, "left": 150, "attrs":
          {} },
8     { "type": "wokwi-led", "id": "led_green", "top": -50, "left": 120, "attrs": { "
          color": "green" } },
9     { "type": "wokwi-led", "id": "led_red", "top": -50, "left": 160, "attrs": { "
          color": "red" } },
10    { "type": "wokwi-buzzer", "id": "buzzer", "top": -50, "left": 200, "attrs": {} }
11  ],
12  "connections": [
13    [ "esp:TX", "relay:IN", "green", [ "h20", "v40" ] ],
14    [ "esp:D2", "led_green:A", "green", [ "h10", "v-30" ] ],
15    [ "esp:D4", "led_red:A", "red", [ "h10", "v-30" ] ],
16    [ "esp:D18", "buzzer:2", "blue", [ "h10", "v-30" ] ],
17    [ "esp:GND.1", "relay:GND", "black", [ "h0" ] ],
18    [ "esp:GND.1", "led_green:C", "black", [ "h0" ] ],
19    [ "esp:GND.1", "led_red:C", "black", [ "h0" ] ],
20    [ "esp:GND.1", "buzzer:1", "black", [ "h0" ] ]
21  ]
22 }
```

4.7 Comportamentos Esperados nos Cenários de Demonstração

Em alinhamento com a etapa de demonstração da DSR e os objetivos específicos do projeto, estruturam-se os comportamentos projetados para os três cenários operacionais que serão submetidos a ensaios em bancada virtual.

4.7.1 Cenário 1: Comportamento Esperado no Fluxo Nominal

No fluxo nominal, prevê-se que o corretor com cadastro ativo requisite a entrada para um imóvel disponível dentro do horário comercial e com agendamento homologado.

Espera-se que o motor ABAC (PDP) execute a inferência lógica em tempo reduzido (< 50 ms) e invoque o módulo criptográfico para assinatura Ed25519 (< 5 ms). Ao apresentar o código QR renderizado na tela do celular à interface óptica do ESP32 na bancada simulada, o comportamento projetado consiste em:

1. Conclusão da verificação matemática da assinatura digital em menos de 10 ms;
2. Comutação do pino GPIO 23 para nível lógico alto por exatamente 5 segundos, acionando a bobina do relé solenoide;
3. Acendimento do LED verde de confirmação e emissão de pulso agudo no buzzer;
4. Transmissão assíncrona bem-sucedida do recibo de confirmação pelo aplicativo celular ao broker MQTT, sem perda de pacotes sob QoS 1.

4.7.2 Cenário 2: Comportamento Esperado frente a Acessos Inválidos e Ataques

Para os ensaios negativos previstos (CT-2.1 a CT-2.4), a hipótese central de segurança requer uma taxa de contenção de 100% de bloqueio efetivo na extremidade desconectada, sem qualquer falso positivo de concessão:

- **CT-2.1 (Token Expirado):** Diante de tokens com timestamp posterior ao campo `exp`, espera-se que o firmware efetue o descarte imediato por estouro de TTL, acionando o LED vermelho (GPIO 4) e registrando a tentativa no log local sem comutação do relé.
- **CT-2.2 (Imóvel Divergente):** Caso um token emitido para a Unidade A seja apresentado na fechadura da Unidade B, espera-se que a checagem do campo `dev` falhe no primeiro estágio algorítmico, bloqueando o processamento antes mesmo da computação criptográfica.
- **CT-2.3 (Assinatura Forjada por Adulteração de Payload):** Diante de adulterações intencionais de bits em campos como vigência ou identificador de usuário, espera-se que a função `verify_ed25519` retorne falso deterministicamente, impedindo a liberação física da porta.
- **CT-2.4 (Ataque de Repetição / *Replay*):** Caso uma credencial consumida anteriormente seja apresentada de forma reincidente, espera-se que a rotina de busca na tabela circular NVS identifique a presença do identificador `jti`, barrando o acesso por duplicidade.

4.7.3 Cenário 3: Comportamento Esperado na Revogação Cadastral

Para a hipótese de revogação cadastral de um corretor na imobiliária, o comportamento projetado divide-se em duas respostas coordenadas:

No ambiente em nuvem, projeta-se que a alteração do status para `SUSPENSO` reflita de forma imediata no banco relacional (PIP). Requisições subsequentes submetidas pelo aplicativo devem ser indeferidas pelo PDP com código HTTP 403 (*Forbidden*), impedindo a emissão de novos tokens.

No nó da fechadura desconectado, o controle do risco residual decorrente de credenciais geradas instantes antes da suspensão deve ser contido pela expiração temporal intrínseca: o token permanecerá operável apenas durante o intervalo remanescente de seu tempo de vida (TTL máximo de 15 minutos). Esgotada essa janela, o relógio interno do microcontrolador rejeitará o token por expiração, ao passo que tentativas de reuso dentro da janela serão inviabilizadas pelo mecanismo anti-replay.

4.8 Resultados Esperados e Discussão de Hipóteses

Em consonância com o protocolo experimental planejado na metodologia, estabelecem-se as metas de desempenho e as hipóteses analíticas que balizarão a coleta de dados durante os ensaios práticos.

4.8.1 Hipóteses de Desempenho Temporal e Latência

A avaliação temporal contempla quatro métricas em cadeia: o tempo de decisão das políticas ABAC (M1), o tempo de cálculo da assinatura assimétrica Ed25519 no servidor (M2), o tempo de verificação matemática da assinatura no microcontrolador ESP32 (M3) e o tempo total de resposta perceptível pelo usuário (M4).

Para a inferência ABAC (M1), a meta de tempo médio inferior a 50 ms apoia-se em estudos prévios de motores de políticas contextuais. Ameer et al. (2022) observaram tempos de decisão entre 15 e 40 ms para regras HABAC em servidores de aplicação. Como a implementação utiliza o framework assíncrono FastAPI (ASGI) associado a consultas indexadas no banco relacional (PIP), o limite de 50 ms garante que a avaliação das políticas lógicas sob a disciplina `deny_overrides` ocorra sem bloqueio de threads de I/O.

Para a assinatura digital no servidor (M2), a meta de tempo inferior a 5 ms decorre das características computacionais da Curva de Edwards. Utilizando a biblioteca `PyNaCl` (baseada na implementação de referência `libsodium` em C), operações com o algoritmo Ed25519 em processadores de servidor x86-64 consomem tipicamente entre 0,05 e 1,5 ms (HAN et al., 2018). A margem de 5 ms absorve variações sob concorrência de requisições sem degradar a capacidade de resposta do backend.

Na extremidade desconectada, a verificação da assinatura Ed25519 no microcontrolador ESP32 a 240 MHz (M3) tem como meta estrita um tempo inferior a 10 ms. Essa delimitação ganha relevância quando confrontada com esquemas criptográficos tradicionais: Han, Du e Lu (2020) mediram uma latência de 339 ms para verificação assimétrica baseada em RSA-2048 em um microprocessador ARM Cortex-A7, atraso já perceptível ao usuário. No ESP32, a multiplicação de ponto na curva Curve25519 via biblioteca `mbedtls` consome menos de 800.000 ciclos de clock (cerca de 2 a 3,5 ms a 240 MHz). O teto de 10 ms fornece margem segura para trocas de contexto no FreeRTOS, garantindo que o destravamento ocorra de forma quase instantânea na porta.

Para a latência total ponta a ponta (M4) — englobando tráfego de rede celular 4G/5G (150 a 250 ms), inferência em nuvem M1+M2 ($<$ 55 ms), leitura óptica do QR Code e verificação local M3 ($<$ 10 ms) —, a meta fixada é inferior a 500 ms. Esse patamar apoia-se em diretrizes clássicas de ergonomia computacional (limite de 1 segundo para manutenção do fluxo contínuo de pensamento sem percepção de lentidão) e nas conclusões de Satanasaowapak, Manasathien e Treebupachatsakul (2021) sobre o tempo aceitável em fechaduras inteligentes residenciais.

4.8.2 Restrições e Consumo de Recursos Computacionais no ESP32

Em nós embarcados que operam de forma isolada, a gestão de memória determina a estabilidade operacional contínua. A métrica M5 estabelece que o consumo de memória RAM Heap no ESP32 não ultrapasse 120 KB durante o pico de decodificação JSON e verificação criptográfica. Fisicamente, o ESP32 dispõe de 520 KB de SRAM interna, dos quais aproximadamente 280 a 300 KB permanecem utilizáveis pela aplicação após a carga do FreeRTOS e pilhas nativas. O teto de 120 KB assegura que o firmware ocupe menos de 40% da memória dinâmica disponível, mantendo margem livre contínua superior a 150 KB. Essa folga, associada à alocação estática com a biblioteca `ArduinoJson` (`StaticJsonDocument`), previne fragmentação de heap e falhas por estouro de memória (*Out-Of-Memory*) (VARDAKIS et al., 2024).

Para a memória permanente Flash ROM (M6), a meta restringe a ocupação do binário a menos de 35% da partição de aplicação. O ESP32 DevKit v1 padrão integra 4 MB (4.096 KB) de memória Flash SPI. Em arquiteturas embarcadas de produção, adota-se o esquema de particionamento duplo para atualizações remotas seguras (*Over-The-Air* – OTA), no qual existem duas partições de aplicação espelhadas (`app0` e `app1`) com cerca de 1.300 a 1.400 KB cada (32% a 35% da flash total). Manter o binário estático abaixo de 35% é um requisito técnico mandatório para assegurar a viabilidade de atualização e mecanismos de recuperação automática (*rollback*) (RESEARCHERS, 2024).

4.8.3 Capacidade de Mensageria e Eficácia de Segurança Projetada

Para a métrica M7, a meta de suportar mais de 100 mensagens por segundo no broker Eclipse Mosquitto decorre do dimensionamento de pico de administradoras imobiliárias de médio e grande porte. Mesmo em carteiras com centenas de propriedades e dezenas de corretores ativos em campo nos horários de maior visitação (início da tarde e finais de semana), a taxa de check-ins concorrentes raramente atinge dezenas de acessos por segundo. Como o broker Mosquitto foi desenvolvido em linguagem C com arquitetura assíncrona leve (AUTHORS, 2024), a meta de 100 msg/s sob entrega garantida QoS 1 assegura uma margem de folga de cinco a dez vezes sobre o tráfego estimado, sem risco de enfileiramento ou descarte de pacotes de auditoria (AMEER et al., 2022).

Por fim, a métrica M8 exige 100% de bloqueio efetivo frente a tentativas anômalas (CT-2.1 a CT-2.4). Em controle de acesso físico a propriedades desocupadas, a tolerância a falsos positivos de concessão é zero. A fundamentação é matemática: a verificação de assinatura digital sobre curvas de Edwards é uma operação determinística estrita; qualquer alteração de um único bit no payload serializado invalida a prova criptográfica, forçando o algoritmo a retornar falso. Aliado ao buffer circular na partição NVS que impede a reutilização de identificadores `jti`, o sistema garante a rejeição categórica de acessos expirados, adulterados ou duplicados (SATANASAOWAPAK; MANASATHIEN; TREEBUPACHATSAKUL, 2021).

4.8.4 Quadro Consolidado de Metas e Resultados Esperados

O Quadro 12 consolida as variáveis de avaliação, as metas numéricas projetadas, os critérios de tolerância e a fundamentação teórica de cada parâmetro a ser aferido nas baterias de 50 repetições.

Tabela 12 – Quadro consolidado de metas quantitativas e resultados esperados da avaliação experimental.

#	Variável / Métrica	Meta	Critério de Aceitação	Fundamentação Teórica na Literatura
M1	Latência Decisão ABAC (ms)	< 50	Ausência de bloqueios de thread no servidor.	Arquitetura assíncrona ASGI/FastAPI com regras JSON compiladas (AMEER et al., 2022).
M2	Assinatura Ed25519 (ms)	< 5	Execução em tempo constante sem canal lateral.	Operação algébrica otimizada da biblioteca PyNaCl/libsodium (HAN et al., 2018).
M3	Verificação no ESP32 (ms)	< 10	Operação matemática instantânea no microcontrolador.	Desempenho de curvas elípticas Curve25519 a 240 MHz via `mbedtls` (RESEARCHERS, 2024).
M4	Latência Ponta a Ponta (ms)	< 500	Tempo total imperceptível ao usuário na porta.	Limites de usabilidade e tolerância humana em IoT (SATANASAOWAPAK; MANASATHIEN; TREEBUPACHATSAKUL, 2021).
M5	Memória RAM Heap (KB)	< 120	Folga contínua $>$ 150 KB sem vazamento de memória.	Alocação estática com ArduinoJson para evitar fragmentação de heap (VARDAKIS et al., 2024).
M6	Ocupação Flash ROM (%)	< 35	Binário compacto em partição de 4 MB.	Eficiência de código em C/C++ embarcado sobre FreeRTOS (RESEARCHERS, 2024).
M7	Vazão MQTT (msg/s)	> 100	Zero descarte de pacotes sob nível QoS 1.	Protocolo MQTT leve para telemetria em brokers assíncronos (AMEER et al., 2022; AUTHORS, 2024).
M8	Taxa Bloqueio Ataques (%)	100	Índice zero de falsos positivos de concessão.	Robustez matemática da assinatura Ed25519 e buffer anti-replay NVS (SATANASAOWAPAK; MANASATHIEN; TREEBUPACHATSAKUL, 2021).

Fonte: Elaborado pelo autor com base nas diretrizes de projeto e na literatura (2026).

4.8.5 Discussão Teórica e Confronto de Hipóteses com o Estado da Arte

A estruturação das metas do artefato estabelece vantagens teóricas frente aos trabalhos correlatos mapeados na literatura.

Em comparação com o protótipo de Han, Du e Lu (2020), que reportou latência de verificação assimétrica de 339 ms em um microprocessador ARM Cortex-A7 utilizando chaves RSA, a meta projetada neste trabalho (M3 < 10 ms com o algoritmo Ed25519) representa uma redução de magnitude superior a trinta vezes no tempo de cálculo no ESP32. Esse avanço

decorre da eficiência aritmética das curvas elípticas de Edwards frente às exponenciações modulares pesadas exigidas pelo padrão RSA tradicional.

Frente ao trabalho de Satanasaowapak, Manasathien e Treebupachatsakul (2021), cuja fechadura baseada em QR Code e senhas temporárias (OTP) depende de enlace local Wi-Fi para recepção de comandos na residência, a proposta aqui apresentada elimina completamente a dependência de infraestrutura de rede no imóvel. O transporte da credencial ocorre por leitura óptica unidirecional e a auditoria é transferida assincronamente à rede celular do próprio smartphone do corretor, eliminando a exposição de portas de rede da fechadura a ataques cibernéticos locais.

Por sua vez, em relação ao modelo HABACα formalizado por Ameer et al. (2022), projetado para residências dotadas de conectividade permanente e gateways de borda ativos, o presente trabalho adapta o paradigma de autorização contextual para o cenário de vacância imobiliária. A inteligência decisória permanece na nuvem corporativa da imobiliária, enquanto o nó físico no imóvel restringe-se a validar a prova criptográfica assinada e a aplicar restrições temporais estritas.

A confirmação dessas hipóteses de desempenho durante a fase de testes empíricos do trabalho permitirá validar a viabilidade de fechaduras inteligentes baseadas em IoT operando com segurança e rastreabilidade plena em ambientes desprovidos de conexão de rede local.

5 Conclusão

Apresente:

- resumo dos resultados - contribuição da pesquisa - limitações - sugestões para trabalhos futuros

5.1 Trabalhos futuros

Referências

AMEER, S. et al. An attribute-based approach toward a secured smart-home IoT access control and a comparison with a role-based approach. *Information*, v. 13, n. 2, p. 60, 2022.

AUTHORS, V. Continuous authentication for IoT smart home environments. *Network Security*, 2022.

_____. Reconceptualizing smart home automation: Enforcing secure and user-friendly communication for delegating general access. In: *International Conference on Advances in Computing, Communication and Control Methods (ICACCM)*. [S.l.: s.n.], 2024.

_____. IoT-based smart lock with real-time person detection using YOLOv5 and mobile app integration. *RCSI*, 2025.

HAN, D. et al. Trustworthiness and a zero leakage OTMP-P2L scheme based on NP problems for edge security access. *Sensors*, v. 20, n. 8, p. 2231, 2020.

_____. Offline authentication scheme based on blockchain technology for smart lock. In: *Proceedings of the 2018 ACM International Conference*. [S.l.: s.n.], 2018.

HEVNER, A. R. et al. Design science in information systems research. *MIS Quarterly*, v. 28, n. 1, p. 75–105, 2004.

PEFFERS, K. et al. A design science research methodology for information systems research. *Journal of Management Information Systems*, v. 24, n. 3, p. 45–77, 2007.

RESEARCHERS, I. A survey on smart home authentication: Toward secure, multi-level and interaction-based identification. *IEEE Xplore*, 2021.

_____. 5G-SSAAC: Slice-specific authentication and access control in 5G. *IEEE Xplore*, 2022.

RESEARCHERS, M. Performance evaluation of IoT microcontrollers for access control systems via simulation. *MDPI*, 2024.

SATANASAOWAPAK, C. et al. Residential access control system using QR code and the IoT. *International Journal of Electrical and Computer Engineering (IJECE)*, v. 11, n. 4, p. 3267–3274, 2021.

SILVA, V. C. et al. IoT and blockchain for smart locks. *IEEE Xplore*, 2023.

VARDAKIS, G. et al. Review of smart-home security using the internet of things. *Electronics*, v. 13, n. 16, p. 3343, 2024.

ZHOU, Y. et al. Perils and mitigation of security risks of cooperation in Mobile-as-a-Gateway IoT. In: *Proceedings of the 2022 ACM SIGSAC Conference on Computer and Communications Security (CCS '22)*. [S.l.: s.n.], 2022.